Signed, Sealed, Leaked: Trust Beyond Signature for MCP Toolchains

Aun Yichiet, Mohammed A. Alhartomi, Tan Jing Jie, Waqas Nadeem, Adeb Salh, Shankar Karuppayah, and Tan Sin Chee

arXiv:2611.06585v1 [cs.CR] 4 Nov 2026

***Abstract*—AI agents rely on third-party tools, such as Model Context Protocol (MCP) servers, whose publishers can be authenticated and whose execution can be restricted by runtime security policies. Yet authenticity does not guarantee benign behaviour: a legitimately signed tool may perform its advertised function while concealing malicious code that leaks confidential information. We demonstrate this trust failure with a signed MCP tool that embeds sensitive data in requests to a policy-allowed destination. Meta's MCPGuard-Dynamic, a state-of-the-art runtime defence, blocks a direct exfiltration attempt in the same run, yet fails to prevent this attack in every trial. We introduce germline execution, which limits information disclosure without inspecting or trusting tool implementations. Each tool invocation runs in ephemeral copies forked from a data-free germline process, each receiving only information authorised for its destination. Even if malicious code executes, what it can disclose is bounded by the data available to its copy. Under explicit assumptions on copy confinement and a data-free germline, we prove sink noninterference for every signed release and, for releases deterministic within our replay model, show that a verified witness establishes a flow violation. Across 153 attack runs, no unauthorised disclosure was detected under germline execution, compared with 5.9–74.5% of runs under baseline defences and an ablation. Invocations served by a single copy completed in 10–49 ms, 2–28× faster than restarting the tool for every invocation, the conventional way to clear state. These results show that data-isolated execution protects agent toolchains against malicious code concealed within authenticated software.**

***Index Terms*—AI agents, Model Context Protocol, software supply chain, code signing, information-flow control, noninterference, sandboxing, Trojans.**

I. Introduction

AI agents now act by calling tools. Through the Model Context Protocol (MCP) [1], tool calls have become the new API layer of software: an agent hands a user's documents, databases and messages to third-party tools that run as long-lived processes next to it. Ecosystems trust these tools through code signing and pinned publisher keys, from TUF-style metadata [2] and Sigstore [3] to signed agent-skill catalogues [4]. A signature, however, proves only who published the exact bytes, not what the bytes do once they run. Malicious code can therefore be embedded inside a trusted, signed tool: the tool does its advertised job while a hidden routine, like a Trojan, leaks the user's data. This is not hypothetical. The XZ backdoor [5] showed that maintainer-signed releases can carry hidden code, and agent tools show the same pattern in skill backdoors [6], exfiltrating MCP servers [7] and backdoored copies of legitimate agent extensions [8].

Runtime defences go beyond the signature: confinement such as AgentBound [9] and MCPGuard-Dynamic [10] limits the files and destinations a tool may reach, and agent information-flow control (IFC) such as FIDES [11] and CaMeL [12] labels tool replies. Neither is designed for a Trojan in the tool's own code that slips stolen data into a request to a destination the tool is allowed to use, by carrying data across calls or mixing the items of one call.

Even the state-of-the-art defence misses it. We ran Meta's MCPGuard-Dynamic, a recent open-source kernel-level defence for MCP tool calls, with least-privilege policies for a six-call session over HR, board, finance and public items. In its strongest evaluated configuration (per-call policy enforcement with its eBPF controls active), its egress control works as designed: in the same run, a raw-socket transfer to an unlisted host is blocked in every trial. Yet a signed release of an OCR tool, pool, keeps items from earlier calls and discloses them inside the next request to the authorised OCR destination, in every trial and under all seven MCPGuard configurations; smuggle does the same with permitted files the call did not need (Table I). For pool, no disclosure was detected under germline execution, the mechanism we propose; smuggle is measured in our scripted matrix. The pattern holds beyond these releases: across 91 variants we generated, an egress allowlist of this class stops all 71 that send to an attacker-owned host but none of the 20 that send to a policy-allowed host (Section VII-C). This marks the boundary of destination-based confinement, not an implementation flaw: MCPGuard decides where a process may send data and does not promise item-level information-flow control. Because the attack needs nothing more than publishing a signed tool or update, a signed Trojan is one of the most direct ways to attack an agentic AI system.

Invocation purity. Per-call output labelling relies on what we call *invocation purity*: what a call sends to a destination depends only on data that destination may see. Destination-based confinement relies on it as well whenever its destination policy is taken as assurance that each destination receives only items it may see. A long-lived tool process violates it by carrying state across calls (pool) or mixing items of different

Aun Yichiet, Waqas Nadeem and Adeb Salh are with the Faculty of Information and Communication Technology, Universiti Tunku Abdul Rahman, Kampar, Malaysia (e-mail: aunyc@utar.edu.my; waqas@utar.edu.my; adebali@utar.edu.my). *Corresponding author: Aun Yichiet.*

Mohammed A. Alhartomi is with the Department of Electrical Engineering, University of Tabuk, Tabuk, Saudi Arabia (e-mail: malhartomi@ut.edu.sa).

Tan Jing Jie is with the National University of Singapore, Singapore (e-mail: tanjingjie@nus.edu.sg).

Shankar Karuppayah is with Bitranger and with CYRES, Universiti Sains Malaysia, Penang, Malaysia (e-mail: shankar@bitranger.io).

Tan Sin Chee is with ABLEs, Malaysia (e-mail: sc@ables.com.my).

TABLE I

(A) SINGLE-HARNESS COMPARISON: TRIALS WITH A DETECTED DISCLOSURE OUT OF 3 (CANARIES PER TRIAL). "3/3 (2)" DISCLOSED; "0/3" PREVENTED; "0/3°" PAYLOAD INACTIVE (SENDS NOTHING EVEN WITHOUT ENFORCEMENT); C-FULL: MCPGUARD'S PROXY, POLICY AND EBPF; C-FULL-PERCALL: POLICY RE-APPLIED PER CALL; BENIGN COMPLETES 6/6 CALLS EVERYWHERE. MCPGUARD COLUMNS RUN EACH VARIANT IN MCPGUARD'S TOOL FORMAT, THE OTHERS OUR RELEASE; ONLY THE POOL ROW IS MATCHED. (B) MCPGUARD'S OWN RUNNER, ALL SEVEN CONFIGURATIONS (3 TRIALS EACH, 105 RUNS); CONFIGURATIONS WITH IDENTICAL RESULTS ARE GROUPED.

Variant	Sig+Pin	Confined +IFC	C-full	C-full-percall	GERMLINE
pool	3/3 (2)	3/3 (2)	3/3 (2)	3/3 (2)	0/3
smuggle	0/3°	0/3°	3/3 (3)	3/3 (3)	0/3°
direct	3/3 (3)	0/3	0/3	0/3	0/3
launder_text	3/3 (1)	3/3 (1)	0/3°	0/3°	0/3
benign	0/3	0/3	0/3	0/3	0/3

(b) MCPGuard configurations	benign	direct	pool	smuggle	launder_text
C0, C-AB, C-app (no eBPF)	0/3	3/3 (3)	3/3 (2)	3/3 (3)	0/3°
C-ebpf, C-full, C-AB+ebpf, C-full-percall (eBPF)	0/3	0/3	3/3 (2)	3/3 (3)	0/3°

clearance within one call (smuggle; Section II-C).

Germline execution. Instead of judging whether a tool's code can be trusted, our mechanism controls what data the code can see. Every call runs in disposable copies of the tool, forked from a clean *germline* process that never holds user data, and each copy receives only the data its destination may see; the copies are discarded after the call. Hidden code still runs, but it has nothing to leak: whatever it sends to a destination, that destination was already allowed to see. Formally, the mechanism enforces one invariant from outside the tool: a request to a destination depends only on the items that destination is cleared to see in the current call, on state kept for its clearance horizon, on replies it may receive and on public inputs. Before the tool runs, a Plan step groups the consumers and declared destinations by the items each may see, its *view*, and the germline forks one sandboxed copy per group. Groups follow declared destinations, so which copies exist never depends on secret data, and state crosses calls only through per-horizon slots held outside the copies. Prevention rests on these copies alone; a separate evidence layer of twin copies and verifiable witnesses exposes releases whose requests diverge, and a dampening policy adapted from BGP route-flap damping [13] suppresses repeat offenders. We build on secure multi-execution [14] and per-request state reset [15]; Section II-D states what is new when the adversary is the signed tool itself.

Contributions. This paper makes three contributions.

- **The gap.** We identify invocation purity as the assumption behind per-call output labelling and behind item-level readings of destination-based confinement, separate its two failure modes, and demonstrate both against MCPGuard-Dynamic (Sections II-C and VII-B).
- **Germline execution and its guarantees.** Under stated confinement and data-free-germline assumptions we prove sink noninterference for every signed release and output labels that cover stored state; a verified witness proves a flow violation for tools deterministic within the replay model; and Plan uses the fewest copies of any black-box mechanism with data-independent run selection (Sections IV and V).
- **Prototype and evaluation.** We implement GERMLINE for unmodified Python MCP servers on stock Linux and answer five research questions. No canary disclosure was detected in 153 attack runs (baselines and an ablation: 5.9–74.5%), in 91 variants we generated, or with an LLM-driven agent that completes 7 of 7 tasks; single-copy calls take 10–49 ms, 2–28× faster than a fresh process per call (Sections VI and VII).

The proofs, the complete result tables, the dampening analysis, the ethics statement and the artifact description are in Appendices A to D.

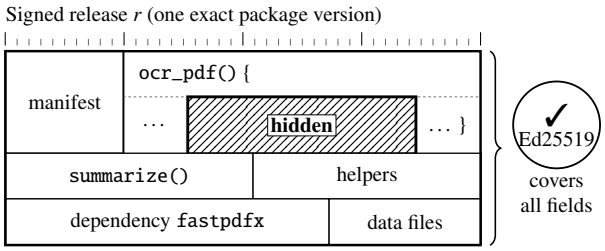

Fig. 1. A valid signature proves who published the bytes, not what the bytes do. Each field stands for one part of a signed release; the hatched field is a hidden routine inside `ocr_pdf` that stashes input from earlier calls and appends it to the next authorised request, and the Ed25519 signature covers it exactly as it covers every other field.

II. BACKGROUND AND MOTIVATING ATTACK

A. MCP tools and signed releases

An MCP server exposes callable functions, called tools, to an agent host over JSON-RPC [1]. Local servers are ordinary processes that the host usually starts once and keeps alive for the whole agent session [9], so one process receives the inputs of every call it serves.

A *release* is one exact signed package version (manifest, code and dependencies), identified by its hash. The publisher signs it with an Ed25519 key [16], TUF-style metadata [2] names the current release, and the host pins the publisher key and verifies every later release. This chain authenticates provenance and promises nothing about what those bytes do with the data they receive: a hidden routine, or a dependency bumped to a compromised version, is covered by the signature like the code around it (Fig. 1).

B. What current guards bind

Each defence beyond the signature binds authority to one object (Table VIII). Pre-deployment analyses and honey tests bind it to the code before it runs [17], [18], [19], where dormant routines can stay inactive. Confinement binds it to the server process and the *destination hosts* it may reach, where a destination host is the target host of a request, identified by its

DNS name or IP address, with all its ports and paths; we say *destination* from here on. AgentBound enforces a per-server manifest in a session-long container [9], and MCPGuard-Dynamic an eBPF/BPF-LSM policy on files, programs and destinations, optionally re-applied on each call [10]. Both stop contact with unlisted hosts; the content of a request to an allowed host is outside their design scope.

Agent information-flow control (IFC) binds labels to data. CaMeL [12] and, as described in its paper, FIDES [11] label each tool reply chiefly from the tool's identity and the current call's inputs (in CaMeL, also from the reply's content type) and block flows to consumers not cleared for the label. This is correct when the reply depends on the current call alone; Section VII-C shows a stateful reply that CaMeL labels public.

Request-reset isolation restores a clean state before each request, by snapshot and restore in Groundhog [15] or by a fresh process per call, our baseline; items of one call still share a process.

C. Invocation purity

Per-call output labelling rests on one expectation, which we call *invocation purity*: a call sends each destination only data that destination may see. Destination-based confinement does not itself require it, but a deployment that reads a destination policy as item-level confidentiality relies on it. The invariant we enforce is that *a request to destination d depends only on d's cleared current items, d's horizon state, admissible replies and public inputs* (the release, metadata and public nondeterminism such as the clock). Returned values obey the same rule through their labels (Corollary 2); Definition 5 is the formal version. A hidden routine can break the invariant in two ways without violating a confinement or labelling policy.

The first failure mode is *cross-call state*. In our running example (Fig. 2a–b), the carry-over Trojan pool in `ocr_pdf` keeps a salary sheet labelled *hr* from an earlier call. When a later call sends an invoice labelled *finance* to the declared destination `ocr.example`, which is cleared for finance data, the hidden routine appends the salary sheet. The signature is valid, the destination is allowed and the reply carries the invoice's label, yet the salary sheet reaches a host not cleared for it; a fresh process per call would remove the stash.

The second failure mode is *within-call mixing*. A call to `ocr_annotate` (Fig. 2c) holds the invoice and, as a reference, the salary sheet; the agent is cleared for both, `ocr.example` only for the invoice. A hidden routine that copies the salary sheet into the OCR request needs no state, so neither a fresh process nor a per-call policy separates the two items. smuggle is a variant in which the extra data comes from the tool's permitted read set rather than from the call's items.

D. Closest prior combination

The closest prior design combines secure multi-execution, one execution per security level [14] (also proposed for language models [20]), with request-reset isolation [15] and agent IFC [11], [12], and addresses both failure modes in principle. Against an adversarial signed release it would still need four elements: a germline checked to be data-free before every fork despite the release's own initialisation code; grouping by *declared* destinations fixed before any content is read; horizon-keyed state slots whose labels cover stored state; and witnesses that a third party can verify by re-running the signed release. Grouping by contacted hosts instead discloses one bit per call (Lemma 2). Section VIII gives the full comparison.

III. Threat Model and Problem Statement

An agent invokes third-party MCP tools on a machine holding labelled data, such as HR records and invoices. Each call receives labelled items, may contact the destinations (Section II-B) its function declares in the signed manifest, and returns a result to consumers such as the agent, a mail recipient or a public post. An item may reach a destination or consumer only if its clearance covers the item's label.

A. Adversary and trust assumptions

The adversary controls the whole signed release: its code, manifest, initialisation code and dependencies, and any number of updates, which may be obfuscated or contain dormant or content-triggered logic. Every release is validly signed by the pinned publisher key and performs its advertised function, so signature checks and functional tests pass. The adversary knows our mechanism, may target it from initialisation code, and may control colluding releases, some input contents and any destination; we do not rely on the agent's model to choose tools or recipients correctly.

Labels and clearances come from the deployer's policy, not from the release. The declared destinations of each function and an optional determinism declaration come from the signed manifest; the adversary chooses them, so they affect how many copies run and how much weight a divergence carries, but never what a destination may receive. Call metadata (function name, arguments, item names and labels) is public and trusted for routing only, while secret content travels as a labelled item (A5). The trusted computing base is the kernel, the broker that mediates every request a tool sends, the policy and signature verification; Section V-B states assumptions A1–A6, which also exclude timing channels.

B. Attack vectors and compositions

A tool call is shaped by four inputs, and any of them may be adversarial. The primary vector, V1, is the tool code itself: hidden functionality in a signed release, introduced during development, by an authenticated update or by a compromised dependency, as in the xz backdoor [5]; our corpus includes a release whose only change is such a dependency bump (dep). V1 code can realise both failure modes of Section II-C, and Section VII-C measures V1 alone and in each composition (Fig. 3).

Table II covers the other vectors, each with a *compositional* attack from our corpus whose parts are harmless alone but disclose data together. All reduce to one data-flow question: does a request or a returned value carry an item to a sink not cleared for it? The guarantees for V1 therefore cover the

TABLE II
THE OTHER ATTACK VECTORS, THE COMPOSITION WITH V1 IN OUR CORPUS THAT EXERCISES EACH, AND WHAT GERMLINE EXECUTION PROVIDES.

Vector	Corpus example	How data reaches a destination	What germline execution provides
V2 input content	trigger: fires on a marker in a document	Sent directly or inside authorised requests	A parser exploit acts as V1 (Theorem 1); model instructions act via V4
V3 upstream outputs	xtool: one server drops data, another ships it	Added to the second server's authorised requests	Same as V2, with content from another tool; it reaches a later call only as a labelled item
V4 agent decisions (tool, recipient)	launder, launder_text: earlier data hidden in a return value	The agent forwards the value to a less-cleared sink	Labels cover items, replies and stored state of a returned value (Corollary 2), so CaMeL- and FIDES-style policies receive these labels

data flows of V2 and V3; for V4 we supply the labels that CaMeL [12] and FIDES [11] consume, while prompt injection without hidden code remains their task.

We focus on disclosure because it is the harm that signature pinning, MCPGuard's egress control [10] and CaMeL/FIDES-style labels are built to stop. Other payload types are out of scope, harmful commands to a permitted destination are a stated boundary, and action control remains a composable layer.

C. Problem statement and requirements

The problem is to run a possibly adversarial signed release so that each destination and consumer learns only what it is cleared for, while flow-compliant releases keep working at low cost. A release is *flow-compliant* if every request it sends satisfies the invariant of Section II-C; otherwise it commits a *flow violation* (Definition 5).

R1 Prevention. The defence must enforce the invariant of Section II-C, formalised as sink noninterference (Definition 5), for arbitrary signed code and without detecting the Trojan; values returned to consumers must carry labels that cover their items, replies and stored state (Corollary 2).

R2 Evidence. For releases the broker hosts, requests that differ with and without uncleared items yield a trigger that probe replay classifies; a resulting witness can be checked by a third party by re-running the signed release, proves a flow violation, and is never false for tools deterministic within the replay model.

R3 Transparency and cost. A flow-compliant release must produce the same results as without the defence (Definition 7), with the fewest isolated executions per call within its class (Theorem 3) and per-call latency small relative to an LLM-driven episode.

IV. DESIGN: GERMLINE EXECUTION

A. Overview and vocabulary

Germline execution enforces the invariant of Section II-C from outside the tool: instead of recognising hidden code, it arranges each call so that the only execution able to reach a destination never received the items that host may not see. As in Weismann's germ-plasm theory [21], nothing an execution acquires flows back to the process from which later executions start. At install time, the agent platform verifies the signature and starts the release in a *germline*, a confined process that loads the code and runs its initialisation but never receives user data. For each call, Plan decides which items each execution holds, and the germline forks one sandboxed *copy* per Plan group (Fig. 2c). A trusted broker delivers each request only from the copy that serves its destination and compares the other copies' requests with it.

We use the notation of Section V-A: item x may flow to destination or consumer d only if $\ell(x) \subseteq c(d)$. A call (*invocation*) to f carries public metadata m, items X, consumers C (typically the agent) and the destinations D_f declared in the signed manifest; a *session* is a sequence of calls. The *view* $V(d)$ is the set of current items d may see; the *horizon* κ of a copy, the intersection of its group members' clearances, bounds its state slot $\sigma[\kappa]$ and the replies it may receive. A *trigger* is an online request mismatch, and a *verified witness* a trigger that offline replay attributes to items the destination may not see. Views and horizons can differ: two destinations of a public-only call, `ocr.example` cleared for *finance* and `mail.example` for *projx*, share a view, but a reply from `ocr.example` may carry finance data, so Plan gives them separate copies and slots.

B. Plan and declared-destination splitting

Plan reads metadata, labels, clearances, D_f and C, never item contents. It groups the destinations and consumers in $D_f \cup C$ by view, then splits any group whose destinations differ in clearance, so that every reply a copy receives is cleared for all members of its group. A consumer joins a group of its view whose host clearances all lie inside its own, or else gets a group of its own. Groups run smallest view first, so the requests delivered from every smaller view are recorded before a copy holding more items runs. In Fig. 2c, `ocr.example` is cleared for the invoice's *finance* label and the agent also for the salary sheet's *hr*, so Plan forms two groups; in most calls of our workloads all members fall into one group, and the call needs a single copy.

Splitting on *declared* rather than contacted hosts is essential: under lazy splitting, the copy holding uncleared items decides whether d receives any request, which discloses one bit per call and host (Lemma 2, Section VII-E). With declared-destination splitting, which copies exist never depends on secret data, and within that class Plan uses the fewest copies (Theorem 3).

C. One call end to end

We follow the `ocr_annotate` call of Fig. 2c. Plan returns two groups in order: {`ocr.example`} with view

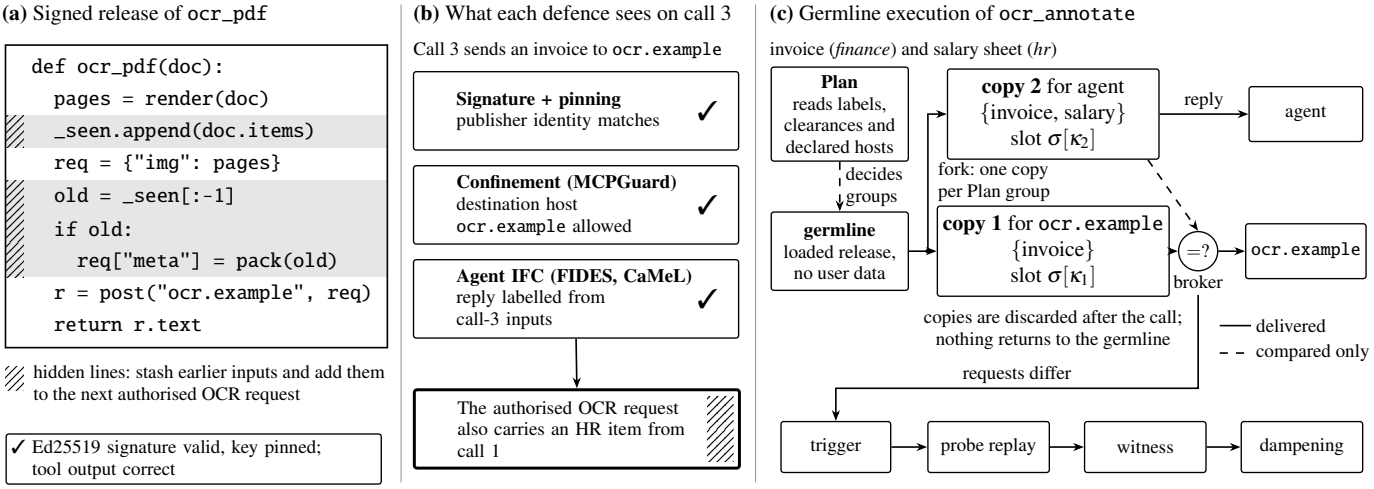

Fig. 2. The running example and the two failure modes of invocation purity. (a) A signed release whose `ocr_pdf` contains hidden lines (hatched; simplified pseudocode) that stash earlier inputs and add them to the next authorised OCR request. (b) Cross-call state: on call 3, the pool release appends the HR item stashed in call 1 to the invoice request; signature, destination and per-call reply label all check out, so the HR data reaches `ocr.example`. (c) The panel switches on purpose to within-call mixing: germline execution of a call to `ocr_annotate` that holds an invoice (*finance*) and a salary sheet (*hr*) (Section IV-B). Only copy 1, which holds the invoice alone, delivers to `ocr.example` (solid); the request of copy 2, which also holds the salary sheet, is compared but never delivered (dashed). Under germline execution, call 3 of (b) runs as one copy whose finance-horizon slot never held the HR item.

$\{\text{invoice}\}$ and horizon *finance*, then $\{\text{agent}\}$ with view $\{\text{invoice}, \text{salary sheet}\}$ and horizon $\{\textit{finance}, \textit{hr}\}$. Copy 1 is forked from the germline and receives the metadata, the invoice, the salary sheet as a name with empty contents, the twin inputs (a frozen clock and seed) and the finance slot with its label. The broker delivers its request to `ocr.example`, records it with the reply as the first request to that host, and returns the reply. Copy 1 serves no consumer, so the broker discards its return value and kills it with all its descendants.

Copy 2 is forked next and receives both items and the slot of its own horizon. Its requests to `ocr.example` are never delivered; the broker compares its k-th request to that host with the k-th request delivered for copy 1. If they are equal, the broker replays the recorded reply, which is admissible because `ocr.example` is cleared only for finance; if they differ, or copy 2 sends more or fewer requests, it records a trigger and answers with the placeholder $\perp$. Copy 2 returns its value to the agent, labelled with the join of its view's labels, the clearances of hosts whose replies reached it and its slot's label, and is killed. Offline, probe replay checks whether a trigger stems from the salary sheet (Section IV-F).

D. The germline call

Algorithm 1 gives the procedure. Before every fork, the broker checks that the germline is still data-free: it has a single thread (G1), no descriptor except its control socket, `/dev/null` streams and read-only allowed files (G2), and no shared writable mapping (G3); otherwise an inherited pipe or mapping could carry bytes between copies, so a release that fails a check is refused. Copies run one at a time, smallest view first, which reduces the parallel-copy timing channel we measured (Section IX-B). A copy that exceeds its time budget is killed and its consumers receive an error, so it cannot suppress later groups or delay destinations served by earlier copies; only groups with equal or incomparable views may wait up to the budget, which is timing (A1).

A request thus reaches a destination only from the copy of that destination's group. Hidden code that adds uncleared items to a request either runs in a copy that has nothing to add or produces a request that is never delivered; in a call with several copies, that request, or an extra, missing, repeated or reordered one, is recorded as a trigger (Theorem 2(c)) at the cost of one digest comparison per request.

E. Per-horizon state slots and labels

Since copies are discarded, flow-compliant tools keep state across calls, such as a session token or a cache, through the broker. A copy reads and writes only the slot $\sigma[\kappa]$ of its horizon, much as a browser keeps cookies per site, so state reaches a later call only if every member of the reading group is cleared for it (Lemma 1). Each slot entry stores the label of everything the writing copy had seen (its view, its slot and the hosts whose replies reached it), and a copy that receives a non-empty slot joins that label into its output label. For example, if call 1 writes an HR item into the agent's horizon slot, the entry is stored with label $\{\textit{hr}\}$; a later public-only call with the same horizon receives the whole slot and returns its value with $L = \{\textit{hr}\}$, which a downstream CaMeL- or FIDES-style policy refuses to forward to a public sink (Table VI).

Destination hosts are stateful too: a host e may remember anything it was cleared to receive, so its reply carries the worst-case label $c(e)$ and is *admissible* for a copy only if $c(e)$ lies inside the clearance of every member of the copy's group. Replies from remote MCP servers follow the same rule, so a reply that re-emits earlier data still carries a correct label (Corollary 2); such tools cannot be forked and receive prevention but no witnesses (Section IX-B).

Algorithm 1 Plan and the germline call. A host e is *comparable* for group g if its group ran before g and $V(e) \subseteq V(g)$; it is *admissible* for g if $c(e) \subseteq c(d)$ for all $d \in g$; $\ell(\sigma)$ joins the labels stored in slot σ ($\emptyset$ if empty). The tripwire also records mismatches with an equal-view host; probe replay always classifies these as state or response divergences.

procedure PLAN(f, m, ℓ, D_f, C) ▷ never reads contents
  $\mathcal{G} \leftarrow$ group $D_f \cup C$ by view $V(d)$
  split each $S \in \mathcal{G}$ until $c(e) \subseteq c(d)$ for hosts e, members $d \in S$
  return $\mathcal{G}$, ordered so that $V(g) \subsetneq V(g')$ puts g first
procedure GERMLINECALL(r, f, m, X, D_f, C)
  $\tau \leftarrow$ (frozen clock, seed); $Rel[e] \leftarrow \langle\rangle$ for $e \in D_f$
  for $g \in$ Plan$(f, m, \ell(X), D_f, C)$ **do**
    if G1, G2 or G3 fails for the germline of r **then** refuse r
    fork copy in fresh net/IPC/PID namespaces; Landlock, no writes
    send m, τ, whole slot $\sigma = \sigma[\kappa(g)]$, contents of $V(g)$
    (other items: name only)
    $L \leftarrow \ell(V(g)) \sqcup \ell(\sigma)$; $n[e] \leftarrow 0$ for $e \in D_f$
    while copy runs, on message msg within budget T **do**
      if msg is a request q to $e \in g$ **then**
        deliver q, get reply ρ; append (q, ρ) to $Rel[e]$
        $L \leftarrow L \sqcup c(e)$; return ρ
      else if msg is a request q to $e \in D_f \setminus g$ **then** ▷ tripwire
        $n[e] \leftarrow n[e] + 1$; $(q', \rho') \leftarrow n[e]$-th entry of $Rel[e]$ ($\perp$ if none)
        if e admissible for g and $Rel[e] \neq \langle\rangle$ **then** $L \leftarrow L \sqcup c(e)$
        if $q = q'$ and e admissible for g **then** return ρ'
        if $q \neq q'$ and e comparable **then** record trigger (g, e, q)
        return placeholder $\perp$
      else if msg is a request to $e \notin D_f$ **then** deny
      else if msg is a state write (key, v) **then** $\sigma[key] \leftarrow (v, L)$
    if deadline reached **then** kill copy and descendants; output error to consumers in g; **continue** with next group
    for comparable e with $V(e) \neq V(g)$ and $n[e] < |Rel[e]|$ **do**
      record trigger $(g, e,$ absent$)$
    kill the copy and all its descendants
    for consumer $c \in g$ **do** output the copy's value with label L

F. Twin execution, witnesses and probe replay

A comparison is evidence only if a flow-compliant release produces identical requests in every copy. The broker therefore fixes twin inputs for each call, chosen without looking at item contents, from which every copy derives its clocks, exposed performance counters, random generators, `os.urandom` and numeric-library seeds. The shim works at the Python level, so native code and the CPU cycle counter lie outside it; they affect evidence only.

A trigger is not yet evidence, because the comparing copy may also differ from the copy g that serves d in its slot or its replies. The *probe* therefore re-runs the release with g's slot, metadata, twin inputs and replies, so that it differs from g only in the items d may not see, and the *control* re-runs g's exact inputs (Definition 6). If the probe's request sequence to d differs on each of N tries while the control never does, the result is an *item witness*, which, for a release deterministic within the replay model, proves a flow violation (Theorem 2). A trigger that disappears in the probe is a state or response divergence (Proposition 1), and a differing control marks nondeterminism beyond twin control (Proposition 2; Table XIV). A verifier holding the release and the named items can repeat probe and control offline from the witness record. A witness must be handled at the clearance of its contents; its hash authenticates the code, not the supplied context, and it is a counterexample to flow compliance, not proof of a past disclosure.

Dampening policy. Evidence feeds a local trust policy, separate from prevention, modelled on BGP route-flap damping [13]: a release's penalty decays with a half-life of $h = 50$ calls to it, refused calls included, grows by $w = 250$ per unverified event, and suppresses the release between thresholds $S = 2000$ and $R = 750$. A verified witness from a release whose signed manifest declares determinism adds 2000 and suppresses it at once. No guarantee of Section V depends on these parameters; Appendix B-E gives the rule and its analysis.

V. Formal Model and Guarantees

A. System model

Definition 1 (Labels, clearances, flow)**.** Each item x has a label $\ell(x) \subseteq \mathcal{T}$ and each destination host or consumer d a clearance $c(d) \subseteq \mathcal{T}$, both public policy inputs; x may flow to d iff $\ell(x) \subseteq c(d)$, and $\sqcup$ is set union.

Definition 2 (Release, call, view)**.** A release r is a signed package identified by its hash. A call $k = (r, f, m_k, X_k, D_f, C_k)$ has function f, public metadata m_k (function name, arguments, item names and labels), labelled items X_k, the destination hosts D_f declared for f in the signed manifest, and consumers C_k of the return value. The view of d is $V_k(d) = \{x \in X_k : \ell(x) \subseteq c(d)\}$; we drop the subscript k when the call is clear.

Definition 3 (Horizon, state slots, twin inputs)**.** A copy serves one Plan group $g \subseteq D_f \cup C_k$ whose members share one view $V(g)$, and has horizon $\kappa(g) = \bigcap_{d \in g} c(d)$; $\kappa_k(d)$ is the horizon of the copy serving d. The broker delivers the whole slot $\sigma[\kappa(g)]$ when the copy starts and accepts writes only to it; each entry is stored with the join of the writer's view labels, its slot's label and the clearances of the hosts whose replies reached it, and $\ell(\sigma)$ joins a slot's entry labels ($\emptyset$ if empty). All copies of the call receive twin inputs $\tau_k = (t_k, s_k)$, a frozen clock and a seed chosen without reading item contents.

Definition 4 (Responses and transcripts)**.** A reply from destination host e carries the worst-case label $c(e)$ and is *admissible* for a copy serving g if $c(e) \subseteq c(d)$ for all $d \in g$. Under the *positional rule*, a copy outside e's group whose j-th request to e matches the j-th delivered one by digest receives the recorded reply if it is admissible, and the placeholder $\perp$ otherwise. The transcript $T_k(d)$ lists the requests and replies of the copy serving d, and $\mathcal{R}_k(d)$ is the resulting reply environment.

Lemma 1 (Slot invariant)**.** *Every value in $\sigma[\kappa]$ is computed only from items labelled inside κ, earlier contents of $\sigma[\kappa]$, public metadata, twin inputs and replies from destination hosts e with $c(e) \subseteq \kappa$, and its stored label lies inside κ.*

Definition 5 (Sink noninterference)**.** Following Goguen and Meseguer [22] with each destination host as a sink, release r satisfies sink noninterference toward d if, in every call k, its request sequence to d is a function of five arguments only:

$$\mathrm{Req}_k(r, d) = F_r\big(m_k,\ X_k|_{V_k(d)},\ \sigma[\kappa_k(d)],\ \tau_k,\ \mathcal{R}_k(d)\big), \quad (1)$$

where $X_k|_{V_k(d)}$ denotes the contents of the items d may see, and the j-th request may depend on the replies $\mathcal{R}_k(d)$ gives to earlier ones. A *flow violation* is a pair of executions that agree on all five arguments but send different request sequences to d; a release with none toward any destination host is *flow-compliant*.

Flow compliance is a property of a release; the mechanism enforces the stronger, release-independent property that whatever d *receives* satisfies Eq. (1).

B. Assumptions

Against the adversary of Section III-A, the theorems rely on six assumptions, enforced as listed in Table XIII.

- **A1** Confinement: A copy's only external channel is its broker socket; copies run one at a time, smallest view first, each ending with its descendants before the next starts. A copy that exceeds a total time budget T is killed, its consumers receive an error, and the other copies run as planned. Whether and how often a request is sent lies inside the model; when it is sent, including where the budget cuts a sequence, is timing and lies outside.
- **A2** Data-free germline: At every fork the germline passes G1–G3 (Section IV-D), and its image M_r was built before any user data existed and depends only on r.
- **A3** Trusted base: The kernel, broker, label policy and signature verification are correct, and the broker delivers each request to its named destination only (no redirects).
- **A4** Twin seeds: A Python-level shim controls the clock, seed, `os.urandom` and performance counters, not the CPU cycle counter. Only Theorem 2 uses A4.
- **A5** Public data is cleared: Metadata is cleared for every destination; secret content travels as a labelled item.
- **A6** Responses: A reply from e is data labelled $c(e)$, served under the rule of Definition 4.

The prototype enforces A1, A2, A6 and the probe through obligations O1–O5 and the per-copy deadline; property and regression tests (Tables VI and XII) support the correspondence between model and prototype for the behaviours they exercise, not for every machine-level behaviour. Section VI states two remaining prototype gaps (Table III).

C. Sink noninterference

Theorem 1 (Sink noninterference)**.** *Assume A1–A3, A5 and A6. For every release r, call k and declared destination host $d \in D_f$, the request sequence $\mathrm{Delivered}_k(d)$ delivered to d satisfies Eq.* (1) *in place of $\mathrm{Req}_k(r, d)$, and hence does not depend on the contents of any item outside $V_k(d)$. If r uses randomness the broker does not control, the distribution of delivered sequences is such a function.*

Corollary 1 (Sessions)**.** *Across a session, what destination host d receives depends only on items labelled inside $c(d)$, from this and earlier calls, and on admissible replies.*

Corollary 2 (Sound output labels)**.** *For a group g with consumer u, let σ_g be the slot delivered to g's copy and E_g the destination hosts whose reply reached it, live or as an admissible recorded reply, together with every admissible host with a non-empty record to which it sent a request. The returned value carries*

$$\ell(g) = \bigsqcup_{x \in V(g)} \ell(x) \;\sqcup\; \bigsqcup_{e \in E_g} c(e) \;\sqcup\; \ell(\sigma_g), \tag{2}$$

which lies inside $c(u)$ and contains the label of every input of the copy: its items, slot entries, replies, and whether a request matched a recorded one.

Corollary 1 covers carry-over attacks such as pool, and Corollary 2 gives downstream policy engines labels that cover stored state.

D. Witnesses and detection coverage

Definition 6 (Probe replay, control, item witness)**.** For a trigger between a comparing copy with view $W \supsetneq V(d)$ and d's group g, the *probe* runs r on m, the contents of W, g's slot $\sigma[\kappa(d)]$ and τ under $\mathcal{R}(d)$, so it differs from g only in the contents of $W \setminus V(d)$; the *control* does the same with g's item contents. An *item witness* for (r, d) is a probe whose request sequence to d differs from the delivered one on each of $N \geq 1$ tries while the control never differs; it records the release hash, d, the item names of both views, the slot snapshot, $T(d)$ and both sequences.

Theorem 2 (Witnesses and detection coverage)**.** *Assume A1–A6; a release is* deterministic within the replay model *if it draws on no source outside A4. (a)* Witness soundness: *if r is deterministic within the replay model and an item witness for (r, d) exists, r has a flow violation toward destination host d. (b)* No false item witnesses: *if such a r is flow-compliant toward d, stateful or not, no item witness for d is produced. (c)* Detection coverage: *in a call in which Plan forks more than one copy, if a copy whose view strictly contains $V(d)$ finishes within its deadline and its request sequence to d differs from the delivered sequence in content, count or order, including a request absent from either, the tripwire records a trigger, and probe replay classifies it as an item witness, a state or response divergence (Proposition 1) or nondeterminism outside A4 (Proposition 2).*

Parts (a) and (b) hold because the probe and g evaluate one function on arguments that differ only in uncleared contents. Part (c) does not cover single-copy calls, where nothing is compared, return values, timing, undeclared hosts, which are denied rather than compared, or copies whose view does not strictly contain $V(d)$; a divergence caused only by sources outside A4 triggers but is never verified.

E. Copies per call

Definition 7 (Data-independent fork rule, transparency)**.** A fork rule is *data-independent* if it fixes, before any run, the runs and their item sets and the rule that selects which run's output each member of $D_f \cup C$ receives, as a function of f, m, labels, clearances, D_f and C only. A mechanism is *transparent* if, for every flow-compliant release, each destination host and

consumer receives exactly what that release produces on its own view with admissible replies.

Theorem 3 (Lower bound on copies)**.** *Call a mechanism* black-box *if it learns a release only by running it and delivers only outputs of runs on item subsets, in which other items arrive as empty names. Consider black-box mechanisms with a data-independent fork rule; releases with one manifest then receive the same runs and the same output rule. (a) Any such mechanism that satisfies Theorem 1 for every release and is transparent must, in every call, run the release on each distinct view among $D_f \cup C$, and within a view once per distinct clearance among its destination hosts, plus once, if there are any, for the consumers whose clearance contains no host clearance of that view. (b)* Plan *creates exactly these runs, so declared-destination splitting is optimal within this class.*

The class matters: under *lazy splitting*, a fork rule that is not data-independent, d's copy is forked only when the full-view copy contacts d.

Lemma 2 (A data-dependent rule discloses one bit)**.** *Under lazy splitting, whether destination host d receives any request in a call is a function of items outside $V(d)$, one bit per call and destination host, which the tripwire cannot see because the delivered request comes from the copy with view $V(d)$.*

The price of a data-independent rule is that the bound counts declared rather than contacted destinations; the existence-bit test measures the bit (Section VII-E), and Appendix A gives the cost of a call.

VI. Implementation

The GERMLINE prototype realises Algorithm 1 on stock Linux without kernel changes, in Python 3.13. Its core has 999 lines (broker with Plan and baselines, germline fork server, confinement, witnesses, dampening); the tool host inside every copy adds 151 lines and the germline for unmodified MCP servers 75. For the comparison with MCPGuard (Section VII-B), the broker also runs inside MCPGuard's own runner. A publisher Ed25519 key [16] signs TUF-style metadata [2] with each release's version, SHA-256 hash and length; the host pins the key and verifies every release, including updates, before extracting it. The signed manifest lists readable paths, destinations and whether the release declares determinism. Other language runtimes would use snapshot-based germlines.

Germline and copies. The germline imports the package and runs its initialisation under a read-only Landlock ruleset [23] with standard streams bound to `/dev/null`, and the broker inspects it through `/proc` for G1–G3 before every fork. Each copy is PID 1 of its own PID namespace, with fresh network and IPC namespaces and a further read-only Landlock layer. Its only channel is a `socketpair` carrying length-prefixed JSON, over which it receives the public metadata, its view's items as `memfd` files, its whole horizon slot and the twin inputs. The tool host then freezes wall-clock time and `datetime`, replaces the monotonic clock and performance counters with a deterministic counter, and seeds `random`, `os.urandom` and `numpy.random`. An optional pool keeps pre-forked, data-free copies ready. For an MCP server, each copy instead continues the server's own stdio loop on a fresh socket, over which the host speaks MCP JSON-RPC, and relays HTTP to the broker over a second socket; servers run without code changes, although git needs a read-write `/dev/null` (Section VII-D).

TABLE III
ENFORCEMENT BOUNDARY OF THE PROTOTYPE.

Aspect	Enforced by GERMLINE	Outside / required
Init reads	Read-only allowlist, no network	Allowlist holds no user data
Descriptors	G2: control socket, `/dev/null`, read-only files	Anything else: release refused
Messages	Three types; broker picks slot, computes labels	No size quotas
Clocks, RNG	Python-level shim (A4)	Native code weakens evidence only
Slots	Per release and horizon; an update has its own	One user per deployment
Destinations	URL host name, compared literally; redirects not followed	DNS and TLS attacks out of scope
Termination	Absolute 30 s budget per copy on the broker's clock	No memory quota

Broker. A copy has no network: the tool host relays its HTTP requests over the channel, and the broker issues every request itself, only for the copy that holds the destination's view, so exactly one copy delivers each external effect. Comparison, positional replay, slot labels and probe replay follow Algorithm 1; the trigger fires at the first mismatch or when a copy ends with a shorter sequence. Each copy has an absolute budget of 30 s from its fork, kept on the broker's clock, so neither the copy's messages nor its frozen clock extend it, and the broker's own network waits end with the budget. A copy that exceeds it, crashes or sends a malformed message is killed with its descendants, its result becomes an error, and the next call proceeds normally. The broker does not follow redirects: a 3xx reply returns to the copy as the destination host's reply.

Enforcement boundary. Each obligation maps to one mechanism and one property test, and regression tests cover slot labels, sequence comparison, the deadline and redirects (Tables VI and XII). Table III states where enforcement ends; the entries in its right column lie outside the model.

VII. Evaluation

We evaluate germline execution against signed releases that perform their advertised function while carrying hidden code, through five research questions: whether a signed tool still discloses data under MCPGuard-Dynamic and whether germline execution prevents it in the same harness (RQ1, Section VII-B); prevention across vectors, compositions, generated variants and stateful remote tools (RQ2, Section VII-C); utility for flow-compliant tools, unmodified servers, stateful workflows and an LLM-driven agent (RQ3, Section VII-D); soundness and coverage of witnesses, including against adaptive releases (RQ4, Section VII-E); and latency and memory

cost (RQ5, Section VII-F). Appendix B-A maps each experiment to its question and result file.

A. Setup and methodology

Testbed and counts. Five MCP servers (documents, SQL, web, lint, mail) each ship a flow-compliant release 1.0.0 and signed updates with hidden code, 52 in total, implementing the 15 attack variants of Section III-B; with two benchmark releases, all 59 signed releases verify against the pinned key and complete their advertised function. We wrote these 59 releases by hand; the generated variants below are a separate corpus. By design, the test world is one user's home directory, small enough to check every flow: PDFs labelled *hr*, *board*, *finance*, *projx* and public, two SQLite databases, a code repository, mail drafts and credential files, each protected item carrying a fresh random canary per trial. The scripted matrix has 51 attack cases (the two cooperating xtool releases form one) in 3 trials, or 153 *attack runs* per runtime, plus 33 benign calls per trial; the single-harness MCPGuard comparison has 5 variants, 5 runtimes and 3 trials (75 runs), and the LLM-driven agent 7 tasks, 6 releases, 4 runtimes and 3 repetitions (504 episodes).

Disclosure oracle. Five HTTP sinks record every byte they receive, and an oracle that runs outside the runtime under test counts a disclosure when a canary, decoded from raw text, URL encoding, nested base64, hex or zero-width characters, reaches a sink whose clearance excludes its label (per recipient for mail). The tables count every detected disclosure in an attack run; a disclosure that also occurs with the flow-compliant release in the same runtime is not attributed to the tool, which concerns six Sig+Pin runs (Fig. 3). Prevention under GERMLINE is structural (Theorem 1 holds for any encoding), whereas the measurements count detected canaries; every zero below is scoped to our corpus and this oracle.

Runtimes. Sig+Pin runs one persistent process per server after signature verification and key pinning; Sig+IFC adds per-call output labels as in FIDES and CaMeL [11], [12]; Confined+IFC adds AgentBound/MCPGuard-class confinement [9], [10] (network namespace, Landlock [23] allowlists, broker egress allowlist); Fresh+IFC also starts a fresh process per call; and the ablation GERMLINE-NoSplit runs one copy per call holding all inputs. We did not integrate a snapshot/restore runtime such as Groundhog [15]: its security effect, a clean state per call without per-destination views, is what GERMLINE-NoSplit isolates, and germline execution already gains its speed by forking a pre-initialised process, so speed claims are relative to a fresh process per call only.

MCPGuard-Dynamic. We built MCPGuard-Dynamic [10] from its public repository (commit `825fdc0a`), enabled the BPF LSM and loaded its four eBPF programs, proxy, policy format and AgentBound reproduction. Our least-privilege policies in its format cover a six-call session that summarises HR and board documents, sends an invoice to the OCR destination (cleared for *finance*) and posts a press-release summary to the public blog. MCPGuard's runner executes its seven configurations (Table I(b)) with a positive control, a raw-socket transfer to an unlisted host. The single harness runs the two strongest, C-full and C-full-percall (per-call policy enforcement), through MCPGuard's proxy and our runtimes through our broker, in one process with the same session, world, canaries and oracle.

Generated variants. The generated variants target the `read_note` tool of MCPGuard's signed note server (commit `825fdc0a`). We generated 92 distinct packages in five families from 189 attempts with a local Qwen3.5-27B model, signed each and admitted it only if its output matches the clean tool and it discloses a canary with no defence, which 91 do (71 send to an attacker-owned host that no policy lists, 20 to a policy-allowed host; protocol in Appendix B-B).

Experiments run on a GPU server VM or a 2-vCPU cloud container (Appendix B-A); numeric libraries run single-threaded in the germline to satisfy G1, and the agent's model runs with reasoning off.

B. RQ1: Matched comparison with MCPGuard-Dynamic

In MCPGuard's own runner, the eBPF configurations stop the raw-socket variant direct, while pool and smuggle disclose through the authorised OCR destination under all seven configurations (Table I(b); per-configuration rows in Table X). In the single harness, pool is the matched result: it stashes items from the HR and board calls and adds them to the next authorised OCR request. Our own smuggle release sent nothing in this session, so its prevention is measured in the scripted matrix (9 of 15 runs disclose under Sig+Pin, 3 under Confined+IFC, none under GERMLINE; Table XI); launder_text reaches no sink in MCPGuard's runner even under C0. GERMLINE produces no witness here, because no copy holds carried-over data or items outside its view.

Takeaway. MCPGuard confines destinations as designed, yet the signed pool release discloses through the authorised OCR destination in 3 of 3 trials under every configuration; none was detected under germline execution.

This marks the boundary of destination-based confinement: MCPGuard binds authority to a process and its destinations, and its per-call mode re-applies the policy while the process and its memory persist, whereas germline execution binds authority to the items each copy may see, so the two compose (Section IX-A).

C. RQ2: Prevention across vectors, generated variants and remote tools

No canary disclosure was detected in 153 attack runs under GERMLINE (Fig. 3). Each baseline binds authority to a different object and so misses a different vector: output labels miss carry-over and laundering, and confinement misses disclosure through permitted destinations, content-triggered code (V1+V2) and a second server that ships what the first dropped (V1+V3). A fresh process per call removes carry-over but still mixes items within a call, and GERMLINE-NoSplit shows that without split views one copy can place protected items in a request to a less-cleared destination. The dependency bump dep discloses under Confined+IFC but not under GERMLINE, and the germline checks refuse the two

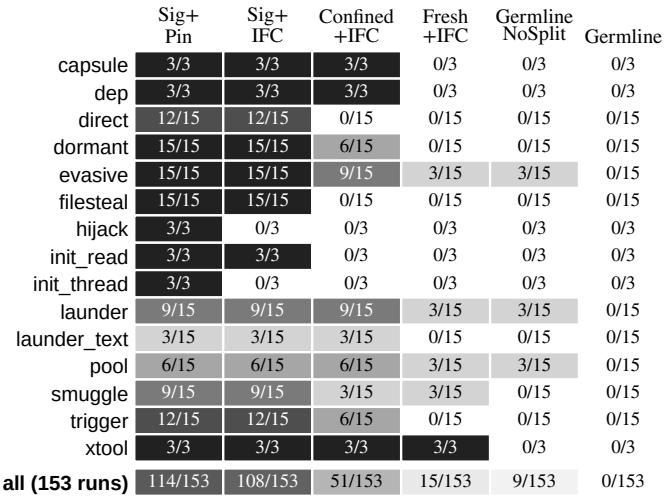

Fig. 3. Scripted security matrix: attack runs with a detected canary disclosure per variant and runtime (51 cases, 3 trials; darker cells disclose more often). Totals: 74.5%, 70.6%, 33.3%, 9.8%, 5.9% and **0.0%**. In 6 Sig+Pin V1 runs only the agent forwards protected replies, so 108/153 (70.6%) are attributable to the tool (Table XI). Every runtime completes 99/99 benign steps.

releases that attack initialisation (init_thread, hijack) before their first call. GERMLINE records 12 triggers in attack runs and none in benign runs (Section VII-E); per-variant disclosure counts are in Table XI.

Generated variants. No canary disclosure was detected for any of the 91 validated variants (20 direct, 20 allowed-request, 20 dormant, 17 triggered, 14 carry-over) in three trials. An egress-allowlist defence of the MCPGuard/AgentBound class prevents the 71 that send to an attacker-owned host and none of the 20 that send to a policy-allowed host, 71 of 91 (78%) overall; germline execution prevents those 20 at the view boundary, because the copy serving the public destination never receives the protected note, so no witnesses arise. As an author-generated corpus, it shows that prevention generalises beyond our hand-written payloads; it is not an independent benchmark and does not show how common such code is.

Stateful remote tools and agent labels. A stateful remote tool, which cannot be forked, discloses 2 canaries to the public sink under per-call labels and none under the worst-case reply labels GERMLINE assigns to remote tools (Section IV-E), which block 3 public posts of a flow-compliant remote tool where per-call labels block 1. In CaMeL's reference interpreter (commit `f083b6b`) with its AgentDojo Workspace policy [12], [24], run on hand-written plans, a second reply of a stateful tool that re-emits a private email body from the first call is labelled public and passes the `send_email` policy to an untrusted recipient in NORMAL and STRICT modes, while sending the body directly is denied. This needs the deployer to list the stateful tool as side-effect-free, a declaration CaMeL takes on trust for exactly the trusted signed component of our threat model. No FIDES code was available to us. Under GERMLINE, a slot-stored HR item recalled by a later public-only call returns labelled *hr* and is refused by a downstream policy, while a public-only control is forwarded (Table VI).

TABLE IV
LLM-DRIVEN AGENT (QWEN3-32B-AWQ CHOOSES EVERY TOOL CALL): CANARIES DISCLOSED PER REPETITION (IDENTICAL IN ALL 3 REPETITIONS) AND TASK SUCCESS.

Release	Sig+Pin	Sig+IFC	Confined+IFC	GERMLINE	Tasks
benign	0	0	0	**0**	7/7
pool	2	2	2	**0**	7/7
dormant	28	28	0	**0**	7/7
launder_text	1	1	1	**0**	7/7
direct	8	8	0	**0**	7/7
smuggle	6	6	3	**0**	7/7

D. RQ3: Utility and compatibility

A tool call is compatible only if its output equals that of the unprotected server, and an LLM task succeeds only if the answer contains the expected key string or the requested post was made, as checked automatically.

LLM-driven agent. Qwen3-32B-AWQ [25] chooses every tool call in seven document tasks, for the flow-compliant release and five releases with hidden code; the agent completes every task and no canary disclosure was detected under GERMLINE (Table IV). With reasoning enabled (Qwen3.5-27B), launder_text disclosed under no runtime, while pool still disclosed 2 canaries under Sig+IFC and Confined+IFC and none under GERMLINE.

Unmodified servers and workflows. We called four unmodified official MCP servers [1] 780 times under GERMLINE: the two tools of `mcp-server-time` and the `fetch` tool of `mcp-server-fetch` 200 times each, and three tools each of `mcp-server-sqlite` and `mcp-server-git` 30 times each. Every call returned the same output as the unprotected server, apart from the clock value of `get_current_time`, while median per-call latency rose from 1.2–18.4 ms to 39.0–110.3 ms (Appendix B). The fetch tool's destination was declared per call from its URL (A5). Two workflows also behave identically, with no witness: a notes tool that keeps its notes through the broker's slot interface, rather than in process memory, adds two notes and shows them; and a call that sends an invoice (*finance*) to the OCR host and returns a payslip (*hr*) only to the agent.

E. RQ4: Evidence quality and detection coverage

We test the three parts of Theorem 2, each against its reference where one exists (Tables V, VI and XII).

Verified witnesses. GERMLINE raised 12 triggers in the scripted matrix, one per trial for four document-server releases. The triggers of pool, launder and evasive reproduce in every probe while the control stays constant, so each yields an item witness and, by Theorem 2(a), a verified flow violation. The capsule trigger vanishes with the destination's slot, a state divergence (Proposition 1); its disclosure was prevented. A witness occupies 7,450 bytes and verifies in about 0.35 s, off the agent's critical path.

No false item witnesses. A flow-compliant tool that reads the clock and draws a nonce yields a false witness in all

TABLE V
EVIDENCE TESTS. *Reference* IS GERMLINE WITH THE NAMED COMPONENT SWITCHED OFF, OR THE NAMED ABLATION. O1–O5 GAVE IDENTICAL RESULTS ON LANDLOCK ABI 7 AND ABI 4.

Test	Reference	GERMLINE
4 triggers from 4 releases	probe replay off: 4/4 confirmed	3 item witnesses (pool, launder, evasive); 1 state divergence (capsule)
Twin test: clock and nonce, 20 runs	no twin: 20/20 false witnesses	0/20
O5: flow-compliant call counter	probe replay off: confirmed (false positive)	state divergence, weight 250
O1: pipe opened at init	release starts	refused (G2)
O2: shared mapping at init	release starts	refused (G3)
O3: child outlives its copy	1 live process	0
O4: reply from a `projx` host, `finance` consumer	1 copy; consumer receives the reply	2 copies; consumer receives the placeholder
Existence bit, 64 calls	lazy splitting: 64/64 bits, 0 triggers	0 bits (mutual information 0.000); triggers on 23/23 and 41/41 secret-dependent attempts
Deniability, 6 noise variants	—	0 HR items at the OCR host

20 runs without twin execution and in none with it. A flow-compliant per-horizon call counter fires the tripwire once, and the probe, replaying with the destination's slot, classes it as a state divergence, as Theorem 2(b) requires.

Detection coverage. Four fixtures exercise Theorem 2(c): the copy holding an uncleared item adds a request, omits one, duplicates one, or reorders two. Each raises one trigger that probe replay verifies as an item witness, and none fires with sequence comparison switched off; a flow-compliant tool that repeats an identical request raises no trigger.

Existence bit. To test Lemma 2, a release sends the cleared invoice to the OCR host in call i only if bit i of a 64-bit secret is one (23 ones); a copy that cannot see the secret falls back to sending or to not sending. With the sending fallback, lazy splitting lets the host recover all 64 bits (0.942 bits per call) without a trigger; with the other, it recovers 41 bits, no more than always guessing zero. Declared-destination splitting discloses 0.000 bits in both settings, and its tripwire fires on every secret-dependent attempt (23/23 added and 41/41 omitted requests).

Deniability, pre-deployment checks and dampening. Six variants that add noise from `os.urandom`, the performance counter or the clock disclosed no HR content, and their secret-dependent triggers verified in 20 of 20 calls. Of the 52 signed releases with hidden code, a static scan flags only 1 after obfuscation, and a three-call honey test flags 28, missing releases of dormant, trigger, pool and smuggle among others. Dampening suppresses an always-diverging release after 9 calls; in simulation, random unexplained divergence on 3% of calls causes false suppression within 10,000 calls with probability 2.4%, and at 1% none within 100,000 calls, while bursty divergence is suppressed more often (Fig. 4(d), Appendix B-E).

TABLE VI
REGRESSION TESTS FOR SLOT LABELS, SEQUENCE COMPARISON, THE PER-COPY DEADLINE AND REDIRECTS, AND THE TWO WORKFLOWS. *Reference* IS GERMLINE WITH THE NAMED COMPONENT SWITCHED OFF, OR THE UNPROTECTED SERVER FOR THE WORKFLOWS.

Test	Reference	GERMLINE
Slot labels (reference: slot-label join off)		
HR item stored, recalled by a public-only call	label $\emptyset$; forwarding to public sink allowed	label $\{hr\}$; forwarding refused
Public-only control	label $\emptyset$; allowed	label $\emptyset$; allowed
Mismatched request to an admissible host with a record	label $\{hr\}$; host clearance missing	label $\{finance, hr\}$
Sequence comparison (reference: comparison off)		
Extra request (empty delivered sequence)	0 triggers	1 trigger; verified item witness
Suppressed request	0 triggers	1 trigger; verified item witness
Duplicated request	0 triggers	1 trigger; verified item witness
Reordered requests	0 triggers	1 trigger; verified item witness
Flow-compliant repeated identical request	0 triggers	0 triggers
Per-copy deadline (test setting 3 s; default 30 s)		
Copy that never finishes	—	killed at 3.0 s; call returns an error; next call succeeds
Copy that keeps sending messages	—	killed at 3.0 s; next call succeeds
Copy waiting on a slow destination host	—	killed at 3.0 s; next call succeeds
Redirects (reference: broker follows redirects)		
302 to attacker host	1 request at attacker host	0 requests; copy receives the 302
307 to attacker host (body kept)	1 request, 21 item bytes at attacker host	0 requests; copy receives the 307
Workflows (reference: unprotected server)		
Notes: add, add, show	"first note. second note.", label $\emptyset$	identical
Invoice to OCR host, payslip to agent	agent value and OCR request	identical; 0 witnesses

TABLE VII
MEDIAN PER-CALL LATENCY OF GERMLINE (P50, MEDIAN OF THREE PASSES), TIME ADDED TO SIG+PIN AND CONFINED+IFC, AND TIME SAVED AND SPEED-UP AGAINST A FRESH PROCESS PER CALL (MS). THE 2–28× SPEED-UP HOLDS FOR THE SINGLE-COPY CASES ONLY.

Case	Co-pies	P50	+ms vs Sig+Pin	+ms vs Conf.	saved vs fresh	speed-up
`noop`	1	9.9	9.9	9.9	272.2	28.4×
`stats`	1	21.8	14.9	14.9	268.0	13.3×
`summarize`	1	48.5	47.0	47.0	58.4	2.2×
`summarize_many`	3	97.3	94.5	94.5	5.5	1.1×

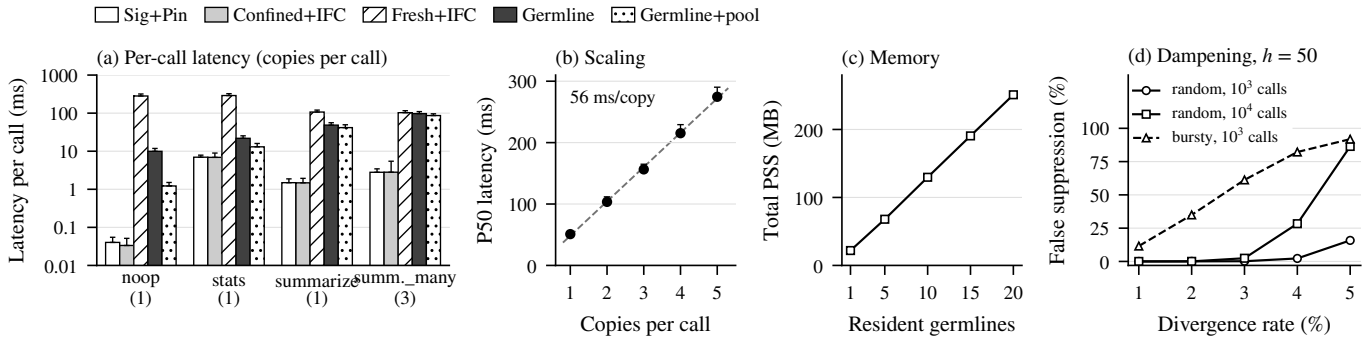

Fig. 4. Cost and dampening. (a) Per-call latency on the server (log scale; P50 with whisker to P99; copies per call in parentheses). Fresh+IFC starts a fresh process per call; Germline+pool forks copies ahead of time. (b) P50 latency grows linearly with copies per call (least-squares slope 56 ms per copy). (c) Total memory (PSS) of resident germlines. (d) Probability that dampening suppresses a release whose unexplained divergence occurs at the given rate, at the operating point $w = 250$, $S = 2000$, $h = 50$ ($p^* = 11.0\%$; Monte-Carlo, Table XV); bursty schedules concentrate the same rate into bursts of 10 calls.

F. RQ5: Cost

Per-call latency. A call served by one copy takes 10–49 ms, 2–28× faster than a fresh process per call (Table VII, Fig. 4(a)); for summarisation, most of the added time is the PDF parse repeated inside the copy. P99 stays within 7 ms of P50, and a pool of pre-forked copies saves a further 7–9 ms.

Multiple copies and scaling. Copies run in sequence, so a call pays for every copy it needs: `summarize_many` runs three copies in 97.3 ms, barely faster than a fresh process (102.8 ms), and latency grows linearly with copies (Fig. 4(b)); external effects are never duplicated. In the 33 calls of the benign session of our scripted matrix, 31 need one copy and 2 need two; extra copies arise only when a call's destinations or consumers differ in view or clearance, so these counts reflect our workload rather than deployed sessions. Sequential copies also reduce a timing channel between copies from 37.9–47.7 bit/s to at most 0.61 bit/s [26].

Memory and end-to-end time. A live copy adds 20 MB PSS (0.98 MB private) to a 35 MB germline, and each resident germline about 12 MB (Fig. 4(c)). The median LLM-driven episode took 2.04 s under GERMLINE and 1.81–1.97 s under the baselines.

VIII. Related Work

Attacks, supply chain, confinement and action control. Beyond the attacks of Section I [6], [7], [8], skills deviate from declared capabilities [17], MCP servers contain risky bidirectional flows [18], and tool poisoning [28] and parser exploits [29] add entry points. TUF [2], in-toto [30] and Sigstore [3] authenticate who published an artefact and how it was built, which can cover hidden code [5], [31]. AgentBound [9] and MCPGuard-Dynamic [10] build on privilege separation [32], [33], capabilities [34] and sandboxing [23] to bind authority to a process and its destinations. Attestation [27], provenance binding [35], trace checks [36], transactional staging [37], action validation [38] and action logs [39], [40] decide whether an action may happen, not which items it carries.

Information flow, multi-execution and accountability. FIDES [11] and CaMeL [12] label tool replies and enforce flow policies in the planner, and TACIT restricts agent code with capture-checked types [41]; their labels are sound when the reply depends only on the current call, whereas Corollary 2 also joins stored state. Our confinement premise follows Lampson [26]. Secure multi-execution [14], faceted values [42] and multi-execution for language models [20] run a program once per security level, DIFC and taint tracking [43], [44], [45], [46] propagate labels, and TightLip [47] and N-variant systems [48] compare replicas. Groundhog restores a FaaS process to a clean snapshot between requests [15]. PeerReview [49] and Arbitrum [50] make faults provable by replay, as our witnesses do for tool releases, and dampening adapts BGP route-flap damping [13]; Section II-D states what germline execution adds to these ideas.

TABLE VIII
PROTECTION EACH DEFENCE CLASS GIVES AGAINST A SIGNED, FUNCTIONALLY CORRECT RELEASE WITH HIDDEN CODE. ● PROVIDED; ○ PARTIAL OR DETECTION ONLY; – NOT PROVIDED; N/A OUTSIDE THE CLASS'S PURPOSE; † MEASURED HERE, OTHER CELLS FROM THE CITED DESIGNS. ASSUMPTIONS: *Sign* [2], [3], [4], TRUSTED KEY; *Scan* [17], [18], READABLE CODE; *Honey* [19], DECOYS REACH THE HIDDEN CODE; *Confine* [9], [10], CORRECT ALLOWLISTS; *IFC* [11], [12], [20], REPLIES DEPEND ONLY ON THE CURRENT CALL; *Attest* [27], WORKLOAD IDENTITY; *Reset*, SNAPSHOT RESTORE [15] (DESIGN) OR FRESH PROCESS PER CALL (MEASURED); GERMLINE, A1–A6, POLICY LABELS, DECLARED DESTINATIONS.

Blocks or provides	Sign	Scan	Honey	Confine	IFC	Attest	Reset	GERMLINE
Undeclared hosts	–†	○†	○†	●†	n/a	–	–	●†
Unrelated file reads	–†	○†	○†	●†	n/a	–	–	●†
Cross-call carry-over	–†	○†	○†	–†	–†	–	○†	●†
Within-call mixing	–†	○†	○†	–†	–†	–	–†	●†
Dormant logic	–†	○†	–†	–†	–†	–	●†	●†
Stateful-tool labels	–	–	–	–	–†	–	○	●†
Per-destination views	n/a	n/a	n/a	n/a	○	n/a	n/a	●†
Verifiable evidence	–	–	–	–	–	–	–	●†

IX. Discussion

A. Deployment and composition

MCPGuard and AgentBound decide where a tool process may connect [10], [9], and germline execution which data each call carries there; each copy can run under the server's

kernel-level policy, so the two stack (not measured). The main policy burden is authoring labels and clearances, as in FIDES and CaMeL [11], [12], and declaring destinations in the manifest [9]. Stateful tools remain compatible when their state passes through the broker's slots (Section VII-D); state kept only in process memory does not carry over, because every copy starts from the data-free germline. Concurrency, throughput, many resident releases and cloud-hosted services are future work.

B. Scope and boundary conditions

Within the disclosure-only scope of Section III-B, four boundaries apply.

Remote tools. A tool we do not host cannot be forked or twinned, so it receives prevention through worst-case reply labels, at a utility cost (Section VII-C), but no witnesses.

Hardware nondeterminism. A release that reads the CPU cycle counter (`rdtsc`) still cannot disclose (Theorem 1 does not use A4), but its divergences stay unverified (Proposition 2).

Timing channels. Covert timing and microarchitectural channels lie outside A1; sequential copies reduce the measured channel (Section VII-F).

Labels from policy and integrity of effects. Theorem 1 protects data as labelled and bounds what a request carries, not whether it is wanted: a harmful data-free request, such as a delete command, needs action control [10], [9], [37], [38]. A flow-compliant tool that passes data across horizons loses that function and fails closed (O4, Table XII).

X. Conclusion

A signature tells an agent who published a tool, and a confinement policy where it may connect, but neither tells it which data each call carries. Germline execution runs each call in copies forked from a data-free germline, provides sink noninterference for every signed release under the stated assumptions, and ties each verified flow violation to the exact release, at 10–49 ms per single-copy call.

Acknowledgments

Author contributions. Aun Yichiet conceived the research problem and the germline-execution mechanism, designed the threat model, the attacks and the experiments, built and ran the testbed, and wrote and edited the manuscript. Mohammed A. Alhartomi reviewed the manuscript and identified inconsistencies that were corrected before submission. Tan Jing Jie provided technical editorial review. Waqas Nadeem cross-checked the generated Trojan designs. Adeb Salh, Shankar Karuppayah and Tan Sin Chee reviewed the conceptual soundness of the work: the threat model, the assumptions and the correctness of the mechanism.

Use of AI tools. The authors used AI assistants (Anthropic Claude and OpenAI Codex) as assistive tools for code implementation, experiment execution, data processing and language editing, and a locally served Qwen3.5-27B model generated the attack-variant corpus described in Section VII-A. The research ideas, the mechanism design, the experimental methodology and the scientific conclusions are the authors' own. The authors reviewed and verified all AI-assisted output and take full responsibility for the content of this paper.

References

[1] Model Context Protocol, "Model context protocol specification, version 2025-06-18," https://modelcontextprotocol.io/specification/2025-06-18, 2025.
[2] J. Samuel, N. Mathewson, J. Cappos, and R. Dingledine, "Survivable key compromise in software update systems," in *ACM Conference on Computer and Communications Security (CCS)*, 2010, pp. 61–72.
[3] Z. Newman, J. S. Meyers, and S. Torres-Arias, "Sigstore: Software signing for everybody," in *ACM Conference on Computer and Communications Security (CCS)*, 2022, pp. 2353–2367.
[4] NVIDIA, "NVIDIA-verified agent skills," NVIDIA Skill Documentation, https://docs.nvidia.com/skills/, 2026.
[5] NIST National Vulnerability Database, "CVE-2024-3094: malicious code in xz/liblzma 5.6.0 and 5.6.1," NVD, 2024.
[6] Y. Feng, Y. Ding, Y. Tan, B. Zheng, X. Li, K. Zhai, Y. Li, Y. Guo, and W. Huang, "SkillTrojan: Backdoor attacks on skill-based agent systems," in *Proc. 43rd International Conference on Machine Learning (ICML)*, ser. PMLR, vol. 306, 2026, pp. 30 026–30 039, arXiv:2604.06811.
[7] J. Park, G. Kim, H. Lee, and J. Park, "Beyond tool poisoning: Attack surfaces of malicious remote MCP servers across LLM platforms," *Electronics*, vol. 15, no. 10, p. 2214, 2026.
[8] CERT-EU, "Beyond the model: backdoors in AI agent harnesses," CERT-EU blog, https://cert.europa.eu/blog/beyond-the-model-backdoors-in-ai-agent-harnesses, Oct. 2026.
[9] C. Bühler, M. Biagiola, L. Di Grazia, and G. Salvaneschi, "AgentBound: Securing execution boundaries of AI agents," *Proc. ACM on Software Engineering*, vol. 3, no. FSE, 2026, arXiv:2510.21236.
[10] Meta, "mcpguard-dynamic: an eBPF sandbox for MCP tool calls," https://github.com/facebook/mcpguard-dynamic, released 27 May 2026, 2026.
[11] M. Costa, B. Köpf, A. Kolluri, A. Paverd, M. Russinovich, A. Salem, S. Tople, L. Wutschitz, and S. Zanella-Béguelin, "Securing AI agents with information-flow control," arXiv:2505.23643, 2025.
[12] E. Debenedetti, I. Shumailov, T. Fan, J. Hayes, N. Carlini, D. Fabian, C. Kern, C. Shi, A. Terzis, and F. Tramèr, "Defeating prompt injections by design," arXiv:2503.18813, 2025.
[13] C. Villamizar, R. Chandra, and R. Govindan, "BGP route flap damping," IETF RFC 2439, Nov. 1998.
[14] D. Devriese and F. Piessens, "Noninterference through secure multi-execution," in *IEEE Symposium on Security and Privacy (S&P)*, 2010, pp. 109–124.
[15] M. Alzayat, J. Mace, P. Druschel, and D. Garg, "Groundhog: Efficient request isolation in FaaS," in *European Conference on Computer Systems (EuroSys)*, 2023, pp. 398–415.
[16] D. J. Bernstein, N. Duif, T. Lange, P. Schwabe, and B.-Y. Yang, "High-speed high-security signatures," *Journal of Cryptographic Engineering*, vol. 2, no. 2, pp. 77–89, 2012.
[17] Y. Wu, T.-L. Li, and H. Liu, "Behavioral integrity verification for AI agent skills," arXiv:2605.11770, 2026.
[18] X. Hou, Y. Zhao, and H. Wang, "Unsafe by flow: Uncovering bidirectional data-flow risks in MCP ecosystem," arXiv:2605.07836, 2026.
[19] N. Li, Z. Ying, X. Wu, Z. Jing, X. Lin, H. Zhang, W. Zhang, J. Lin, Q. Zou, and X. Zhang, "SkillSentry: Adaptive honey worlds for dynamic safety testing of agent skills," arXiv:2608.03485, 2026.
[20] I. Adams, "Noninterference for language models through secure multi-execution," Zenodo preprint, doi:10.5281/zenodo.22097472, 2026.
[21] A. Weismann, *The Germ-Plasm: A Theory of Heredity*. New York: Charles Scribner's Sons, 1893, translated by W. Newton Parker and Harriet Rönnfeldt.
[22] J. A. Goguen and J. Meseguer, "Security policies and security models," in *IEEE Symposium on Security and Privacy*, 1982, pp. 11–20.
[23] M. Salaün, "Landlock: unprivileged access control," Linux kernel documentation, https://docs.kernel.org/userspace-api/landlock.html, 2026.
[24] E. Debenedetti, J. Zhang, M. Balunović, L. Beurer-Kellner, M. Fischer, and F. Tramèr, "AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents," in *Advances in Neural Information Processing Systems (NeurIPS), Datasets and Benchmarks Track*, 2024.
[25] Qwen Team, "Qwen3 technical report," arXiv:2505.09388, 2025.
[26] B. W. Lampson, "A note on the confinement problem," *Communications of the ACM*, vol. 16, no. 10, pp. 613–615, 1973.

[27] Z. Ding, Y. Luo, G. Chen, Q. Shen, and Z. Wu, "ACLE-MCP: Attested capability leases for execution-time trust in remote LLM tool use," arXiv:2609.02690, 2026.
[28] OWASP, "MCP tool poisoning," OWASP Foundation, https://community.owasp.org/attacks/MCP_Tool_Poisoning, 2026.
[29] NIST National Vulnerability Database, "CVE-2025-64512: pdfminer.six arbitrary code execution via crafted PDF input," NVD, 2025.
[30] S. Torres-Arias, H. Afzali, T. K. Kuppusamy, R. Curtmola, and J. Cappos, "in-toto: Providing farm-to-table guarantees for bits and bytes," in *USENIX Security Symposium*, 2019, pp. 1393–1410.
[31] K. Thompson, "Reflections on trusting trust," *Communications of the ACM*, vol. 27, no. 8, pp. 761–763, 1984.
[32] N. Provos, M. Friedl, and P. Honeyman, "Preventing privilege escalation," in *USENIX Security Symposium*, 2003.
[33] A. Bittau, P. Marchenko, M. Handley, and B. Karp, "Wedge: Splitting applications into reduced-privilege compartments," in *USENIX Symposium on Networked Systems Design and Implementation (NSDI)*, 2008.
[34] R. N. M. Watson, J. Anderson, B. Laurie, and K. Kennaway, "Capsicum: Practical capabilities for UNIX," in *USENIX Security Symposium*, 2010.
[35] E. Yocam, V. Vaidyan, P. Kalathas, P. Tague, B. DeBruhl, and Y. Wang, "Agentic AI defense: Decode-time provenance binding for MCP," arXiv:2610.31974, 2026.
[36] Y. Li, Y. Chen, H. Wen, B. Zhang, H. Liu, P. Wang, Y. Feng, and Y. Tian, "VIGIL: Runtime enforcement of behavioral specifications in AI agent skills," arXiv:2606.26524, 2026.
[37] Z. Chen, H. Liu, D. Xu, D. Dong, J. Li, B. Pu, and J. Zhai, "Cordon: Semantic transactions for tool-using LLM agents," arXiv:2606.17573, 2026.
[38] J. Fokou, "Parallax: Why AI agents that think must never act," arXiv:2604.12986, 2026.
[39] B. Ghosh, "Tracekit: Tamper-evident intent-reasoning-action auditing for AI agents," arXiv:2609.35659, 2026.
[40] Microsoft, "Agent governance toolkit," https://github.com/microsoft/agent-governance-toolkit, MIT licence, released April 2026; .NET MCP extensions May 2026, 2026.
[41] M. Odersky, Y. Zhao, Y. Xu, O. Bračevac, and C. N. Pham, "Securing agents with tracked capabilities," in *Proc. ACM Conference on AI and Agentic Systems (CAIS)*, 2026, pp. 812–838, arXiv:2603.00991.
[42] T. H. Austin and C. Flanagan, "Multiple facets for dynamic information flow," in *ACM Symposium on Principles of Programming Languages (POPL)*, 2012, pp. 165–178.
[43] P. Efstathopoulos, M. Krohn, S. VanDeBogart, C. Frey, D. Ziegler, E. Kohler, D. Mazières, F. Kaashoek, and R. Morris, "Labels and event processes in the Asbestos operating system," in *ACM Symposium on Operating Systems Principles (SOSP)*, 2005.
[44] N. Zeldovich, S. Boyd-Wickizer, E. Kohler, and D. Mazières, "Making information flow explicit in HiStar," in *USENIX Symposium on Operating Systems Design and Implementation (OSDI)*, 2006.
[45] M. Krohn, A. Yip, M. Brodsky, N. Cliffer, M. F. Kaashoek, E. Kohler, and R. Morris, "Information flow control for standard OS abstractions," in *ACM Symposium on Operating Systems Principles (SOSP)*, 2007.
[46] W. Enck, P. Gilbert, B.-G. Chun, L. P. Cox, J. Jung, P. McDaniel, and A. N. Sheth, "TaintDroid: An information-flow tracking system for realtime privacy monitoring on smartphones," in *USENIX Symposium on Operating Systems Design and Implementation (OSDI)*, 2010.
[47] A. Yumerefendi, B. Mickle, and L. P. Cox, "TightLip: Keeping applications from spilling the beans," in *USENIX Symposium on Networked Systems Design and Implementation (NSDI)*, 2007.
[48] B. Cox, D. Evans, A. Filipi, J. Rowanhill, W. Hu, J. Davidson, J. Knight, A. Nguyen-Tuong, and J. Hiser, "N-variant systems: A secretless framework for security through diversity," in *USENIX Security Symposium*, 2006.
[49] A. Haeberlen, P. Kouznetsov, and P. Druschel, "PeerReview: Practical accountability for distributed systems," in *ACM Symposium on Operating Systems Principles (SOSP)*, 2007, pp. 175–188.
[50] H. Kalodner, S. Goldfeder, X. Chen, S. M. Weinberg, and E. W. Felten, "Arbitrum: Scalable, private smart contracts," in *USENIX Security Symposium*, 2018, pp. 1353–1370.
[51] W. Kwon, Z. Li, S. Zhuang, Y. Sheng, L. Zheng, C. H. Yu, J. E. Gonzalez, H. Zhang, and I. Stoica, "Efficient memory management for large language model serving with PagedAttention," in *ACM Symposium on Operating Systems Principles (SOSP)*, 2023, pp. 611–626.

APPENDIX A
FULL PROOFS

This appendix proves the statements of Section V. Each proof begins with a one-line restatement and a sentence of intuition; the definitions, assumptions and labels are those of Sections V-A and V-B, and the mechanism is Plan together with Algorithm 1. We use four structural facts, which hold by construction. (P1) Plan groups $D_f \cup C_k$ by view, so all members of a group g share one view, written $V(g)$. (P2) After the split step, every destination host e in a group g satisfies $c(e) \subseteq c(d)$ for every member d of g; since e is itself a member, all destination hosts in g have the same clearance, and it equals the horizon $\kappa(g)$. (P3) Groups run one at a time in an order in which $V(g') \subsetneq V(g)$ implies that g' runs before g; the order depends only on the inputs of Plan. (P4) There is one transcript and replay semantics, that of Definition 4: every reply that a copy receives from a host outside its own group is the reply the positional rule gives from that host's record at that moment, and the probe and the control receive the replies the same rule gives from $T(d)$. In particular, the copy serving d is itself an execution under $\mathcal{R}(d)$, because its transcript $T(d)$ records exactly the replies it was served, and replaying $T(d)$ by position to the same requests returns them again.

A. Slot invariant

Restatement of Lemma 1. Every value in $\sigma[\kappa]$ derives only from items labelled inside κ, earlier contents of $\sigma[\kappa]$, public metadata, twin inputs and replies from hosts e with $c(e) \subseteq \kappa$, and its stored label lies inside κ. The intuition is that a copy of horizon κ never holds anything from outside κ, so nothing it writes can contain such data.

Proof. Call a value κ-*bounded* if it is computed only from the inputs listed in the lemma. We prove, by induction over the global sequence of broker messages (calls in order, groups in Plan order, messages in order), the stronger claim that every message sent by a copy of horizon κ, whether a request, a state write or a result, is κ-bounded, and that every label it stores lies inside κ. The lemma follows, because Algorithm 1 writes $\sigma[\kappa]$ only on a state write from a copy whose horizon is κ.

Consider a copy of group g with $\kappa(g) = \kappa$. At fork its memory is the germline image M_r, which depends only on r (A2). The call message adds the metadata m_k, which is public (A5); the twin inputs τ_k, which the broker chooses without reading item contents (Definition 3); the contents of the items in $V(g)$; and the whole slot $\sigma[\kappa]$ with its label. By (P1), each item $x \in V(g)$ satisfies $\ell(x) \subseteq c(d)$ for every member d of g, hence $\ell(x) \subseteq \kappa$, and the slot contents are κ-bounded, with labels inside κ, by the induction hypothesis. While it runs, the copy's only input is the broker socket (A1), and each broker reply takes one of three forms. (i) A live reply from a destination host e in g: by (P2), $c(e) = \kappa$. (ii) A reply to a request to a declared host e outside g, given by the positional rule (P4): the j-th recorded reply of e if the digests match and e is admissible for g, that is, $c(e) \subseteq \kappa$, and the placeholder otherwise. (iii) A denial or a state acknowledgement: these are constants. Reaching the deadline gives the copy no input; it ends the copy. It remains to check that the *outcome* of the positional rule in form (ii) leaks nothing outside κ. If e is not admissible for g, the broker returns the placeholder whatever the requests are, so the outcome is constant; the same holds if e's group has not yet run, because its record is still empty and the order of groups is fixed by (P3). If e is admissible, the outcome depends on g's own j-th request to e and on the record of e, that is, the requests delivered to e by an earlier group g_e and their replies. By the induction hypothesis that record is $\kappa(g_e)$-bounded, and by (P2) $\kappa(g_e) = c(e) \subseteq \kappa$, so it is κ-bounded as well; a returned recorded reply carries the label $c(e) \subseteq \kappa$ (A6). The copy is a program whose messages are a function of its initial memory and its input stream, and both are κ-bounded; hence so is every message it sends. Finally, the label stored with a state write is the join of g's view labels, the label of the slot it received and the clearances of hosts whose replies reached it, each of which lies inside κ by (P1), the induction hypothesis, (P2) and admissibility. □

B. Sink noninterference

Restatement of Theorem 1. Under A1–A3, A5 and A6, for every release r, the request sequence delivered to each declared destination host d satisfies Eq. (1). The intuition is that only the copy of d's group reaches d, and that copy starts from the data-free image with only d's view, d's slot and public inputs, and later receives only admissible replies or constants.

Proof. Fix a call k and $d \in D_f$, and let g be the Plan group that contains d. By (P1), $V(g) = V_k(d)$, and by Definition 3 the copy of g receives and writes only $\sigma[\kappa_k(d)]$. We proceed in four steps.

Step 1: only g reaches d. Algorithm 1 delivers a request to d only when it comes from the copy of the group that contains d. A request to d from any other copy is answered by the positional rule and never delivered, and a request to a host outside D_f is denied. Hence $\mathrm{Delivered}_k(d)$ consists exactly of the requests that g's copy sends to d, in order.

Step 2: g starts from allowed state. At fork the copy's memory is M_r. By A2, M_r depends only on r: check G1 ensures that no second thread exists that could have received data, G2 ensures that no descriptor exists through which data could arrive later, and G3 ensures that no other copy can write into the copy's memory. The call message then adds m_k (public by A5), the contents of the items in $V_k(d)$, the slot $\sigma[\kappa_k(d)]$ and τ_k; items outside $V_k(d)$ arrive as names with empty contents.

Step 3: g receives only allowed inputs while it runs. By A1, the copy's only channel is its broker socket, and by A3 the broker behaves as specified. By (P4), each reply to a request to a declared host is a live reply of a host in g, which is admissible by (P2), or the outcome of the positional rule, which is an admissible recorded reply or the placeholder; together these are exactly the answers of the reply environment $\mathcal{R}_k(d)$ to g's requests. The remaining broker messages, denials and state acknowledgements, are constants. By the proof of Lemma 1, every reply in $\mathcal{R}_k(d)$ and every outcome of the

positional rule is $\kappa_k(d)$-bounded; in particular, the records it draws on come from groups g_e with $V(g_e) \subseteq V_k(d)$, because $\ell(x) \subseteq c(e) \subseteq c(d)$ for every item they hold, so $\mathcal{R}_k(d)$ does not depend on the contents of items outside $V_k(d)$.

Step 4: conclusion. A copy is a program whose j-th message is a function of its initial memory and the replies to its earlier messages. By Steps 2 and 3, the initial memory is a function of m_k, $X_k|_{V_k(d)}$, $\sigma[\kappa_k(d)]$ and τ_k, and the replies are given by $\mathcal{R}_k(d)$. Induction over the sequence of broker messages shows that the copy's request sequence to d is such a function, and by Step 1 it is the sequence delivered to d. If the copy is killed at the deadline, d receives a prefix of that sequence; which prefix is a matter of timing, which A1 places outside the model. A deadline can change the inputs of a later copy only through the length of a record: if the copy of a group g_e is killed, the record of each host e in g_e is truncated, and a later copy to which e is admissible receives placeholders at the missing positions. That record lies inside $c(e) \subseteq \kappa_k(d)$ by Step 3, and its length is again timing, so the argument above is unchanged for every combination of deadlines. If r draws on randomness that the broker does not control, the copy is a randomised program, and the same induction shows that the distribution of its output stream is a function of the same five arguments. □

Restatement of Corollary 1. Across a session, what d receives depends only on items labelled inside $c(d)$, from this and earlier calls, and on admissible replies. The intuition is that the only path from an earlier call to d runs through d's slot, which Lemma 1 bounds.

Proof. We argue by induction over the calls of the session. In call k, Theorem 1 restricts $\mathrm{Delivered}_k(d)$ to the five arguments of Eq. (1). The metadata is public and the twin inputs are chosen without reading contents. Every item of $V_k(d)$ has a label inside $c(d)$ by Definition 2. Because d belongs to the group whose horizon is $\kappa_k(d)$, we have $\kappa_k(d) \subseteq c(d)$, and by Lemma 1 the slot $\sigma[\kappa_k(d)]$ holds only values derived from items, replies and earlier slot contents labelled inside $\kappa_k(d)$, from this and earlier calls. Finally, every reply in $\mathcal{R}_k(d)$ comes from a host e with $c(e) \subseteq \kappa_k(d) \subseteq c(d)$ and is treated as data labelled $c(e)$ (A6), and by Step 3 of the proof of Theorem 1 the outcome of the positional rule is itself $\kappa_k(d)$-bounded. Hence every argument depends only on information labelled inside $c(d)$ and on admissible replies, which proves the claim for call k given the claim for earlier calls. □

Restatement of Corollary 2. The label $\ell(g)$ of Eq. (2), attached to a value returned to a consumer u in group g, lies inside $c(u)$ and covers every item, slot entry and reply that reached the copy. The intuition is that each of the three joins names one kind of input, and each kind lies inside g's horizon.

Proof. Within clearance. By (P1), $V(g) = V_k(u)$, so every item $x \in V(g)$ satisfies $\ell(x) \subseteq c(u)$. For $e \in E_g$, either e is a destination host of g, so $c(e) = \kappa(g)$ by (P2), or its recorded reply was admissible for g, so $c(e) \subseteq c(d)$ for every member d of g; in both cases $c(e) \subseteq \kappa(g) \subseteq c(u)$. By Lemma 1, every label stored in $\sigma_g = \sigma[\kappa(g)]$ lies inside $\kappa(g)$, so $\ell(\sigma_g) \subseteq \kappa(g) \subseteq c(u)$. All three joins of Eq. (2) therefore lie inside $c(u)$.

Covering every input. By Steps 2 and 3 of the proof of Theorem 1, with u in place of d, the returned value is a function of the data-free image M_r, the public metadata, the twin inputs, the contents of the items of $V(g)$, the entries of the slot σ_g delivered at call entry, and the replies the copy received. Item labels are joined in the first term. Each reply other than the placeholder comes from a host in E_g and carries the label $c(e)$ (A6), which the second term joins; the placeholder is a constant, and the fact that the positional rule returned it is the input discussed in the remark below. For the slot, we show by induction over slot writes that every entry depends only on inputs whose labels lie inside the label stored with it. When a copy writes an entry, its value depends only on the copy's items, the slot it received and the replies received before the write; the stored label joins exactly the labels of these items, the label of that slot, which covers its entries by the induction hypothesis, and the clearances of those replying hosts. Hence every entry of σ_g is covered by $\ell(\sigma_g)$, which the third term joins. Because the whole slot is delivered at call entry, this term is needed whenever the slot is non-empty, whether or not the tool reads it, and it is $\emptyset$ for an empty slot. □

Remark. Eq. (2) is the label the prototype computes (Algorithm 1): it joins the labels of the copy's view, the clearance of every host whose reply reached the copy, including admissible recorded replies from hosts outside g (O4), and the label of the delivered slot. The label regression test (Table VI) checks the slot term: an HR item stored by one call and recalled by a later call with only public inputs is returned with the label *hr*, so a downstream policy engine refuses to forward it to a public sink, whereas a public-only control keeps the label $\emptyset$ and is forwarded. Joining the horizon $\kappa(g)$ instead of $\ell(\sigma_g)$ for a non-empty slot is also sound but coarser, because it labels a recalled public entry as if it held everything the horizon admits. The second term also covers the match outcome: the positional rule tells a copy whether its j-th request to an admissible host e outside g matched the recorded one, since it receives either the recorded reply or the placeholder, so the prototype joins $c(e)$ whenever the copy sends a request to an admissible host with a non-empty record, matched or not. This bit concerns data inside $c(e) \subseteq \kappa(g) \subseteq c(u)$; the match-bit regression test (Table VI) shows the label of a mismatched copy now includes $c(e)$.

C. Witnesses and detection coverage

All runs compared below are executions under the reply environment $\mathcal{R}(d)$ of Definition 4: the copy of d's group g by (P4), and the probe and the control by Definition 6. In g, the items of $W \setminus V(d)$ arrive as names with empty contents, and their names and labels are public metadata. The probe and g therefore agree on the metadata, on the contents of $V(d)$, on the slot snapshot $\sigma[\kappa(d)]$, on τ and on $\mathcal{R}(d)$, and differ only in the contents of the items in $W \setminus V(d)$; the control agrees with g on all of its inputs.

Restatement of Theorem 2. For a release that is deterministic within the replay model, (a) an item witness implies a flow

violation toward d, (b) a flow-compliant release never yields an item witness, and (c) in a multi-copy call, every difference between the delivered sequence and the request sequence to d of a comparing copy whose view strictly contains $V(d)$ and that finishes within its deadline raises a trigger that probe replay classifies. The intuition is that replay equalises every argument d may depend on, so any remaining difference must come from items d may not see.

Proof. (a) Let r be deterministic within the replay model, and suppose an item witness for (r, d) exists, so the probe's request sequence to d differs from the delivered one. By the observation above, the probe and g agree on all five arguments of Eq. (1), including the reply environment through which each of them is answered, and differ only in contents of items outside $V(d)$. Because r is deterministic within the replay model, each execution's request sequence is a function of its inputs and its reply environment, so the two executions agree on the five arguments yet send different request sequences to d, which is a flow violation by Definition 5. The N repeated tries and the control are not needed for this implication when r is deterministic; they make the verdict robust in practice, because a release that draws on a source outside A4 can fail the control and is then never reported as an item witness.

(b) If r is flow-compliant toward d, its request sequence to d is a function of the five arguments of Eq. (1). The probe and g agree on all five, so they send identical sequences to d on every try, and no item witness is produced. The argument uses the slot snapshot $\sigma[\kappa(d)]$ and the reply environment $\mathcal{R}(d)$ in both runs, so it applies to stateful releases as well as stateless ones.

(c) Let g' be a copy with $V(g') \supsetneq V(d)$ that finishes within its deadline; by (P3) it runs after g, so when g' runs the record of d holds every request delivered to d: the complete sequence if g finished, and otherwise the prefix delivered before g was killed at the deadline. For the j-th request of g' to d, the broker compares its digest with that of the j-th request delivered to d, and records a trigger at the first position where they differ or where the record has no j-th entry; when g' ends, it records a trigger if g' sent fewer requests to d than were delivered, including none. A difference in content, count or order, or a request absent from either sequence, produces a first position at which the two sequences differ, or a shorter sequence from g', so each such difference raises a trigger. Probe replay then runs the probe and the control N times each. If the control ever differs from the delivered sequence, the trigger is classified as nondeterminism outside A4 (Proposition 2); otherwise, if the probe differs on all N tries, it is an item witness, and if it never differs, it is a state or response divergence (Proposition 1); a probe that differs on some tries only is also classified as nondeterminism. For a release that is deterministic within the replay model and whose copy g finished, the control never differs and every probe try gives the same result, so the trigger is an item witness, which is a flow violation by (a), or a state or response divergence. If g was killed, the record is a prefix whose length is a matter of timing (A1); whenever the control does not reproduce that prefix, the trigger is classified as nondeterminism and not as an item witness. □

Proposition 1 (State and response divergences)**.** *A trigger whose probe matches the delivered sequence shows that the comparing copy's request depended on its own slot or on replies that d's copy was not served; it is prevented by Theorem 1 but not verified.*

Dampening gives such an event the weight of an unverified event, 250 at the operating point (Table XIV).

Proof. The comparing copy and the probe hold the same items W, metadata and twin inputs, and differ only in the slot ($\sigma[\kappa(g')]$ against $\sigma[\kappa(d)]$) and in the reply environment: the comparing copy is answered live by its own hosts and by the positional rule with its own admissibility, the probe by $\mathcal{R}(d)$. If the comparing copy's sequence to d differs from the delivered one while the probe's equals it, then, by determinism, the difference is caused by the slot or the replies, not by the contents of $W \setminus V(d)$. The comparing copy's requests are never delivered to d (Step 1 of the proof of Theorem 1), so nothing is disclosed. A flow-compliant tool that keeps a call counter per horizon produces exactly this pattern, because counters in different slots differ; hence the event cannot be attributed to a flow violation and receives the unverified weight (Table XIV). □

Proposition 2 (Nondeterministic releases)**.** *If r draws on sources outside A4, the control can fail and replay cannot confirm a flow violation; a release that declared determinism in its signed metadata and fails the control contradicts a declaration its signature attributes to the publisher.*

Proof. If the control, run on g's exact inputs under $\mathcal{R}(d)$, produces a sequence different from the delivered one, then the output of r is not a function of the inputs that the broker controls, so r draws on a source outside A4. The argument of Theorem 2(a) needs determinism to attribute a difference between the probe and g to item contents, so it no longer applies, and no item witness is reported. A release that declared determinism in its signed metadata and fails the control contradicts a statement that its signature binds to the publisher key; by A3, signature verification is correct, so the broken declaration is attributable to the publisher. □

D. Copies per call

The mechanism class is the one stated in Theorem 3. A mechanism in the class treats the release as a black box: it learns the release's behaviour only by running it, and every request it delivers and every value it returns is produced by some run of the release on some item set $U \subseteq X_k$, in which the items outside U arrive as names with empty contents. A data-independent fork rule (Definition 7) fixes these runs, and the output rule that assigns to each member of $D_f \cup C$ the run whose output it receives, before any run starts and without reading the release's code; two releases with the same manifest therefore receive the same runs and the same output rule. For consumers, we read the requirement of Theorem 1 in its natural form for return values: a consumer receives nothing derived from items outside its view.

Restatement of Theorem 3. (a) A mechanism in this class that prevents disclosure for every release and is transparent needs a run on each distinct view among $D_f \cup C$ and, within a view, one per distinct host clearance plus one for the consumers whose clearance contains no host clearance of that view; (b) Plan creates exactly these runs. The intuition is that a flow-compliant release can encode its whole view into each output, so every distinct view, and every clearance that changes which replies a run may see, needs its own run.

Proof. (a), views. Fix a call and a member d of $D_f \cup C$, and consider two releases with the same manifest. Release r_1 sends to every declared destination host, and returns to every consumer, an injective encoding of the contents of all items it holds. Release r_2 sends to each declared host e, and returns to each consumer e, an injective encoding of the contents of the items x with $\ell(x) \subseteq c(e)$; it can compute this set because labels and clearances are public. Release r_2 is flow-compliant, whereas r_1 is not. The output rule assigns to d one run, on some item set U. Because the runs and the output rule are fixed by a data-independent rule from f, m, labels, clearances, D_f and C, which are the same for r_1 and r_2, the rule assigns to d a run on the same set U under both releases. This step uses the data independence of the output rule and not only of the runs: a mechanism that fixed its runs in advance but chose which run's output to deliver after observing the outputs could choose differently for r_1 and r_2. If U contains an item outside $V(d)$, then under r_1 what d receives depends on that item's contents, which contradicts Theorem 1. If U misses an item $y \in V(d)$, then under r_2 what d receives does not depend on y's contents, because y arrives empty, while transparency requires the injective encoding of $X|_{V(d)}$, which does; for some contents of y the two differ. Hence $U = V(d)$, and since the rule is fixed before any run, the mechanism needs a run on each distinct view among $D_f \cup C$.

(a), groups. Let e_1 and e_2 be destination hosts with the same view and $c(e_1) \not\subseteq c(e_2)$. Consider a flow-compliant release that first sends a request to e_1, then sends to e_2 an injective encoding of the reply it received from e_1, and then sends to e_1 a second request that also encodes that reply. The reply of e_1 is not admissible for e_2, so by Definition 7 the transparent sequence for e_2 is computed with the placeholder in its place, while the transparent sequence for e_1 is computed with e_1's real reply. A single run receives either the real reply or the placeholder. With the real reply, its request to e_2 differs from the transparent one whenever the reply differs from the placeholder, and it also carries e_1's data to e_2; with the placeholder, its second request to e_1 differs from the transparent one. Hence e_1 and e_2 need separate runs. The same argument, with a return value in place of the request to e_2, separates a consumer from any destination host whose clearance is not inside the consumer's.

(b). Within each view, Plan partitions the destination hosts by clearance, attaches each consumer to a part whose clearance lies inside its own, and places the remaining consumers of that view together in one part. Two hosts with different clearances violate inclusion in at least one direction, so the groups argument of (a) forces one run per distinct clearance among the hosts of a view. A remaining consumer has no host in its view whose clearance lies inside its own, so (a) forces it to run apart from every host part. Remaining consumers can share a run, because consumers return no replies and every host reply is inadmissible for all of them. Every part Plan creates is therefore forced, and Plan creates no others, so its number of copies equals the lower bound of (a) within this class. □

Restatement of Lemma 2. Under lazy splitting, whether d receives any request reveals one bit of uncleared data per call, invisibly to the tripwire. The intuition is that the existence of d's copy, and hence of any request to d, is decided by a copy that holds data d may not see.

Proof. Under lazy splitting, the copy with view $V(d)$ is forked only when the full-view copy contacts d. Consider a release that, in the full-view copy, contacts d if and only if a chosen bit b of an item outside $V(d)$ equals 1, and whose request to d does not depend on any uncleared content. Then d receives a request exactly when $b = 1$, so the presence of a request reveals b: one bit per call and destination host. When $b = 1$, the delivered request comes from the copy with view $V(d)$ and, by construction, equals the full-view copy's request; when $b = 0$, no copy for d exists and nothing is compared. In neither case does the tripwire record a trigger. Under declared-destination splitting, the copy for d is forked whenever $d \in D_f$, independently of item contents, and the bit disappears. In the existence-bit test, when the copy that cannot see the secret falls back to sending a request, which is the release constructed above, lazy splitting recovers 64 of 64 secret bits (0.942 bits per call); declared-destination splitting recovers no information under either fallback (0.000 bits per call; accuracy at the constant-guess baseline); with declared-destination splitting the sequence comparison also raises a trigger on every secret-dependent attempt, 23 of 23 when the release sends only if the bit is 1 and 41 of 41 when it sends only if the bit is 0 (Section VII-E). □

Cost of a call. A call with $n \leq |D_f \cup C|$ groups and q requests costs n forks, n tool runs and n germline checks, and $O(q)$ digest comparisons; verifying a trigger takes $2N$ replays (probe and control) off the critical path.

APPENDIX B
ADDITIONAL RESULTS

This appendix maps every experiment to its research question and result file, gives the complete result matrices behind the summary tables of Section VII, reports the tests that connect the proofs to the prototype, and analyses the dampening policy. Experiment identifiers (E1–E13) appear only in this appendix and in Appendix D.

A. Experiment map

Table IX links each experiment to the research question it answers, the subsection that reports it, its result file, the platform it ran on and the code it measured. Every experiment marked M ran on the final implementation described in

TABLE IX
EXPERIMENT MAP. RESULT FILES ARE IN `results_cloud/` (C) OR `results_server/evidence_freeze/` (S) OF THE ARTIFACT. PLATFORMS AS IN SECTION VII-A: CLOUD CONTAINER (LANDLOCK ABI 7) OR SERVER (ABI 4). CODE: **M**, THE FINAL IMPLEMENTATION OF SECTIONS IV AND VI; **I**, INDEPENDENT OF THE ENFORCEMENT CODE (DETECTION BASELINES, TIMING CHANNEL); **G**, MCPGUARD'S CONFIGURATIONS ONLY, WITHOUT GERMLINE CODE.

ID	RQ	Reported in	Result file(s)	Platform	Code
E1	RQ2, RQ3	Sections VII-C and VII-D	C: `e1_final.json`	cloud	M
E2	RQ4	Section VII-E	C: `e2_detection.json`	cloud	I
E3	RQ5	Section VII-F	S: `E3_final_pass1.json`, `_pass2`, `_pass3`	server	M
E4	RQ5	Section VII-F	C: `e4_covert.json`	cloud	I
E5	RQ5	Section VII-F	S: `E5_final.json`	server	M
E6	RQ3, RQ5	Sections VII-D and VII-F	S: `E6_final_3rep.json`	server (GPU)	M
E7	RQ3, RQ5	Sections VII-D and VII-F	C: `e7_real_mcp.json`, `e7_more.json`	cloud	M
E8-A	RQ1	Section VII-B	S: `E8A_refresh_20261103T140804.json`	server	G
E8-C	RQ1	Section VII-B	S: `E8C_final.json`	server	M
E9	RQ4	Section VII-E	C: `e9_existence_bit.json`, `e9_deniability.json`	cloud	M
E10	RQ2	Section VII-C	C: `e10_remote_tool.json`; CaMeL check script and log	cloud	M
E11	RQ4	Section VII-E	C: `e11_witness.json`	cloud	M
E12	RQ4	Section VII-E, Appendix B-E	C: `e12_montecarlo.json`, `e12_dampening.json`, `e12_sweep.json`; `e12_montecarlo_h100.json` ($h = 100$)	cloud	M
E13	RQ2	Section VII-C	S: `E13_final_3trial.json`	server	M
Twin	RQ4	Section VII-E	C: `e_twin_falsealarm.json`	cloud	M
O1–O5	RQ4	Section VII-E, Table XII	C: `obligations.json`; S: `OBLIG_final.json`	both	M
Regression	RQ2–RQ4	Sections VII-C to VII-E, Table VI	C: `review_tests.json`	cloud	M

Sections IV and VI, with slot labels, the match bit, sequence comparison, the absolute per-copy deadline and the broker without redirects, and with determinism read from the signed manifest.

B. Security results

Generation protocol for the generated variants (E13). We generated the variants ourselves. They target the `read_note` tool of MCPGuard's signed note server, at the same commit `825fdc0a` as the MCPGuard build of Section VII-A. A pipeline built with an LLM coding agent (Codex) prompts a local Qwen3.5-27B model on vLLM [51] (temperature 0.8, seed $13000 + i$ for attempt i, at most 1800 tokens, reasoning off). Each prompt asks for one pure Python function `candidate(data, state, phase, triggered)` that returns the effects prescribed for its family (for example, return the stored data on the second phase for carry-over), forbids imports, files, sockets and process calls, and asks for a control and data flow distinct from the eight most recent accepted structures; a static checker enforces these rules, and fixed adapters around the unchanged `read_note` handler turn the returned effects into requests. Of 189 attempts, 97 were rejected at generation and 92 were packaged as distinct programs (unique normalised syntax trees) in five families: direct (20), allowed-request (20), dormant (20), triggered (18) and carry-over (14). We adapted each package to our runner, signed it, and admitted it only if its output matches the clean tool and it discloses a canary with no defence. The adaptation rewrites the packaging (manifest fields, module layout and call scenario) and connects the generated canaries to our oracle; the payloads already sent their requests through `urllib`, which the broker relays, and the admission check confirms that every admitted variant still discloses without a defence. Variants are distinct as normalised syntax trees; we did not measure their semantic similarity within a family. All 92 are functional, and 91 are admitted: one triggered variant did not disclose without a defence and was dropped. We tagged each admitted case by where it sends data: 71 to an attacker-owned host that no policy lists, and 20 to a host the policy allows.

MCPGuard in its own runner (E8-A). Table X reports all seven MCPGuard configurations on the six-call session of Section VII-A, with three trials each (105 runs). The positive control behaves as intended: direct, a raw-socket transfer to an unlisted host, discloses in every trial under the three configurations without MCPGuard's eBPF programs and in no trial under the four configurations that load them. pool and smuggle, which place carry-over and in-manifest data inside the authorised request to the OCR destination host, disclose in every trial under all seven configurations, including C-full-percall. launder_text does not disclose under any configuration in this runner, including C0, which enforces nothing, so the zero does not reflect enforcement; the variant is therefore measured under our runtimes in E8-C, E1 and E6. The benign release discloses nothing and completes its session under every configuration. These rows agree with the single-harness comparison of Table I.

Security matrix per variant (E1). Table XI breaks the 153 attack runs per runtime of Fig. 3 down by attack variant, and Fig. 3 in Section VII-C shows the same counts as disclosure rates. The breakdown shows which object each defence binds authority to. Confinement in Confined+IFC stops every variant

TABLE X
E8-A: MCPGUARD-DYNAMIC, ALL SEVEN CONFIGURATIONS, IN MCPGUARD'S OWN RUNNER. CELLS GIVE TRIALS THAT DISCLOSE OUT OF 3, WITH CANARIES DISCLOSED PER TRIAL IN PARENTHESES. EVERY DISCLOSURE BY POOL AND SMUGGLE REACHES THE AUTHORISED OCR DESTINATION HOST; EVERY DISCLOSURE BY DIRECT REACHES THE ATTACKER-OWNED HOST. THE LAST FOUR CONFIGURATIONS LOAD MCPGUARD'S FOUR EBPF PROGRAMS.

Configuration	benign	direct	pool	smuggle	launder_text
C0	0/3	3/3 (3)	3/3 (2)	3/3 (3)	0/3
C-AB	0/3	3/3 (3)	3/3 (2)	3/3 (3)	0/3
C-app	0/3	3/3 (3)	3/3 (2)	3/3 (3)	0/3
C-ebpf	0/3	0/3	3/3 (2)	3/3 (3)	0/3
C-full	0/3	0/3	3/3 (2)	3/3 (3)	0/3
C-AB+ebpf	0/3	0/3	3/3 (2)	3/3 (3)	0/3
C-full-percall	0/3	0/3	3/3 (2)	3/3 (3)	0/3

that needs an unlisted destination host (direct, filesteal) and every attack on initialisation (init_read, init_thread, hijack), but not the remaining ten variants: those that travel inside authorised requests (pool, smuggle, launder, launder_text), those that wait or react to content (dormant, trigger), the adaptive variants evasive and capsule, the dependency bump dep, and the cross-tool composition xtool. A fresh process per call in Fresh+IFC removes most carry-over but still discloses in 3 of 15 runs each for evasive, launder, pool and smuggle, and for xtool in every run, because one call still mixes differently labelled items. The ablation GERMLINE-NoSplit closes the cross-tool case but still discloses through the within-call variants evasive, launder and pool, which is the gap that declared-destination splitting closes. GERMLINE discloses in none of the 153 runs and records 12 triggers along the way, which feed the witness evaluation of Section VII-E. Prevention costs no utility in this matrix: the benign workload completes 99 of 99 steps correctly under every runtime, and the benign release discloses in 0 of 15 runs under GERMLINE. The counts in Fig. 3 and Table XI include every detected disclosure in an attack run, including disclosures that the agent makes itself. Under Sig+Pin, which has no output labels, the agent forwards protected replies itself: in 3 of the 15 benign-release runs, and in all 6 attack runs of hijack and init_thread (marked †), in which the tool itself discloses nothing. By the attribution rule of Section VII-A, these 6 runs are not attributable to the tool, so the tool discloses in 108 of the 153 Sig+Pin runs, as under Sig+IFC; the gap between 114 and 108 is the agent's own forwarding. The vector column follows the mapping of Section III-B: the eleven V1 variants contribute 105 runs, trigger 15 runs to V1+V2, xtool 3 runs to V1+V3, and the two laundering variants 30 runs to V1+V4.

Remote-tool labels and CaMeL labelling check (E10). For a flow-compliant remote tool that mixes sensitivities, the worst-case reply labels of Section VII-C complete 0 public posts, with 3 attempts blocked, where per-call labels complete 2, with 1 blocked; this is the utility cost noted in Section IX-B. CaMeL labels a tool's return value from the tool's identity and that call's arguments and keeps no record of earlier calls. In the check of Section VII-C, run without a language model on CaMeL's reference interpreter at commit `f083b6b`, a stateful

TABLE XI
E1 PER ATTACK VARIANT: ATTACK RUNS WITH A DETECTED DISCLOSURE, OUT OF THE n RUNS IN THE LAST COLUMN (3 TRIALS EACH). RUNTIMES AS IN SECTION VII-A; NOSPLIT IS GERMLINE-NOSPLIT. †THE AGENT FORWARDS PROTECTED REPLIES ITSELF; THE TOOL DISCLOSES NOTHING IN THESE RUNS, SO 108 OF THE 114 SIG+PIN DISCLOSURES ARE ATTRIBUTABLE TO THE TOOL.

Variant	Vec.	Sig+ Pin	Sig+ IFC	Conf. +IFC	Fresh +IFC	No-Split	GERMLINE	n
capsule	V1	3	3	3	0	0	0	3
dep	V1	3	3	3	0	0	0	3
direct	V1	12	12	0	0	0	0	15
dormant	V1	15	15	6	0	0	0	15
evasive	V1	15	15	9	3	3	0	15
filesteal	V1	15	15	0	0	0	0	15
hijack	V1	3†	0	0	0	0	0	3
init_read	V1	3	3	0	0	0	0	3
init_thread	V1	3†	0	0	0	0	0	3
pool	V1	6	6	6	3	3	0	15
smuggle	V1	9	9	3	3	0	0	15
trigger	V1+V2	12	12	6	0	0	0	15
xtool	V1+V3	3	3	3	3	0	0	3
launder	V1+V4	9	9	9	3	3	0	15
launder_text	V1+V4	3	3	3	0	0	0	15
Total		114	108	51	15	9	0	153

tool that the deployer declares side-effect-free returns, in its second reply, a private email body received in its first call; the reply is labelled public and passes the `send_email` policy to an untrusted recipient in both NORMAL and STRICT modes, while sending the private body directly is denied. CaMeL's default policy denies the undeclared tool's first call. For FIDES we rely on its paper's description of per-call labelling [11].

C. Implementation correspondence

Boundary details. Table III summarises the enforcement boundary. In more detail, the initialisation allowlist covers the interpreter, libraries, CA and time-zone data, the release and the runtime, with no writable path; the broker's environment is inherited without the `http_proxy` variables. Broker messages are `effect`, `state_put` and `result`, and requests to undeclared hosts are denied. Each release has its own broker object, a new clearance gets a new slot, and calls run sequentially; a deployment shared by several users must key slots by user as well. Host aliases are distinct destinations. Broker requests time out after 10 s or at the copy's deadline, whichever comes first, and redirects are returned to the copy unfollowed. The deadline bounds a copy's wall-clock time, and with it its CPU time; there is no memory quota. Absence of a request is compared, its timing is not.

Obligations. The proofs of Appendix A rely on five implementation properties, the obligations O1–O5. Table XII lists for each obligation what could go wrong without it, the mechanism that discharges it, and a property test on a flow-compliant fixture that exercises it directly. Each test runs with the mechanism switched off and on, on both platforms (Landlock ABI 7 in the cloud container and ABI 4 on the server), with identical results.

Enforcement of the assumptions. Table XIII maps each assumption of Section V-B to the mechanism that enforces it in

TABLE XII
OBLIGATIONS O1–O5: WHAT EACH PREVENTS, ITS IMPLEMENTATION, AND ITS PROPERTY TEST WITH THE MECHANISM SWITCHED OFF AND ON. RESULTS ARE IDENTICAL ON LANDLOCK ABI 7 (CLOUD) AND ABI 4 (SERVER).

	Without the mechanism	Implementation	Property test	Switch off → on
O1	The germline could hold pipes, sockets or other descriptors created during initialisation, or inherited standard streams.	Before every fork, check G2: only the control socket, `/dev/null` and read-only regular files; standard streams bound to `/dev/null`.	Release whose initialisation opens a pipe.	Release starts → release refused (G2).
O2	The germline could hold an anonymous shared writable mapping.	Before every fork, check G3: no shared writable mapping.	Release whose initialisation maps shared memory.	Release starts → release refused (G3).
O3	A copy's descendants could outlive it.	Each copy runs as PID 1 of its own PID namespace, so its descendants terminate with it.	Tool that leaves a sleeping child process.	1 live process after the call → 0.
O4	Recorded replies could reach larger views regardless of clearance, and Plan would not split by clearance.	Admissibility test on replies; clearance split in Plan; output labels include the clearances of replying hosts; slots keyed by horizon (Definition 3).	Consumer cleared for *finance*; reply from a host cleared for *projx*.	1 copy, consumer receives the reply → 2 copies, consumer receives the placeholder.
O5	Verification would replay each copy with its own slot and without the reply transcript.	Witnesses record the reply transcript; `verify()` runs the probe replay (Definition 6) and the control (Definition 6) and classifies the outcome.	Flow-compliant per-horizon call counter.	1 trigger, confirmed as a flow violation (false positive) → probe classifies it as a state divergence (weight 250).

TABLE XIII
ASSUMPTIONS A1–A6: HOW THE PROTOTYPE ENFORCES EACH ONE AND HOW IT IS TESTED.

Assumption	Enforced by	Prototype status and test
A1 Confinement	Fresh network and IPC namespaces per copy; each copy is PID 1 of its own PID namespace; Landlock read-only allowlist (system paths, package, `/proc/self`) with no writable path; on Landlock ABI ≥6, signals and abstract sockets scoped; copies run one at a time, smallest view first; a copy that exceeds its absolute deadline on the broker's clock is killed with its descendants, its consumers receive an error, and the other copies run as planned.	Enforced (O3 and the deadline). A lingering child process: 1 live process with the PID namespace switched off, 0 with it on, on ABI 4 and ABI 7. A copy that never finishes, one that keeps sending messages and one waiting on a slow destination host are each killed at the deadline, and the next call succeeds (Table VI). Sequential copies reduce the parallel timing channel measured in E4 (37.9–47.7 bit/s in parallel, at most 0.61 bit/s sequentially; Section IX-B).
A2 Data-free germline	The broker checks the germline through `/proc` before every fork (G1 one thread, G2 descriptors, G3 shared mappings) and refuses the release if a check fails; numeric libraries pinned to one thread.	Enforced (O1, O2). Releases whose initialisation opens a pipe or maps shared memory are refused, on ABI 4 and ABI 7.
A3 Trusted base	Assumption: kernel, broker, label and clearance policy, signature verification. The broker does not follow redirects, so requests go only to the named destination.	Assumed; redirect test: a 302 and a body-preserving 307 reach the attacker host with redirect-following on (1 request each, 21 item bytes for 307) and 0 requests with it off (Table VI).
A4 Twin scope	The tool host freezes wall-clock time and `datetime`, replaces the monotonic clock and performance counters with a deterministic counter, and seeds `random`, `os.urandom` and `numpy.random` per call.	Enforced as stated; the CPU cycle counter (`rdtsc`) lies outside the twin scope (Section IX-B); prevention does not depend on A4. Twin test: 20/20 false witnesses without twin execution, 0/20 with it. E9: secret-dependent noise drawn from `os.urandom` or the performance counter yields 20/20 verified witnesses; noise behind a random coin raises none, because both twins draw the same coin.
A5 Public metadata	All copies receive the same metadata; items outside a copy's view arrive as a name with empty contents.	Holds; the experiments pass only paths and flags as arguments, and secret content travels as labelled items.
A6 Responses	The broker returns a destination host's reply to a copy only if it is admissible, by position in that host's recorded sequence, and a placeholder otherwise; Plan splits hosts of different clearance.	Enforced (O4). A *finance*-cleared consumer receives a *projx*-cleared host's reply with the clearance split switched off and the placeholder with it on.

the prototype and to the test that checks it. A3 is the trusted base and is assumed rather than enforced. A1 does not depend on the Landlock ABI: Landlock ABIs below 6 do not scope signals and abstract sockets, but each copy runs as PID 1 of its own PID namespace, which terminates every descendant with the copy on all ABIs. For A2, check G1 requires numeric libraries to run single-threaded in the germline, which the germline environment configures (Section VII-A).

Evidence and regression tests. Table V summarises the evidence tests of Section VII-E, and Table VI the tests for slot labels, sequence comparison, the per-copy deadline, redirects and the two workflows of Section VII-D. In both tables, each row compares GERMLINE with a reference: the mechanism with the named component switched off, the named ablation, or, for the workflows, the unprotected server.

Replay outcomes. Table XIV maps each outcome of probe replay (Section IV-F) to the event the prototype records and to its dampening weight. A verified witness carries the full weight 2000 only for a release that declared determinism, because for any other release the control is a statistical check.

D. Cost and compatibility

Per-call latency (E3). Fig. 4(a) in Section VII-F shows the per-call latency behind Table VII: bars are the median of the

TABLE XIV
REPLAY OUTCOMES, THE RESULTING EVENT (AS NAMED BY THE PROTOTYPE), AND ITS DAMPENING WEIGHT.

Replay outcome	Meaning	Event	Weight
Probe differs on all N tries; control never differs	Item witness: requests depend on uncleared items (Theorem 2)	`verified` if determinism declared, else `verified_undeclared`	2000 / 250
Probe matches; trigger came from slot or replies	State or response divergence (Proposition 1)	`unverified`	250
Control differs; determinism declared	Signed determinism declaration not kept (Proposition 2)	`declared_broken`	2000
Control differs; determinism not declared	Nondeterminism beyond twin control	`unverified`	250

per-pass P50s over three passes of 200 calls after 40 warm-up calls, and whiskers reach the largest P99 of the three passes.

Scaling (E5). Fig. 4(b,c) shows how latency grows with the number of copies per call and how memory grows with the number of resident germlines, about 12 MB PSS per additional germline (Section VII-F).

Unmodified MCP servers (E7). Every call to the two tools of `mcp-server-time` and to `mcp-server-fetch` (200 per tool) and to three tools each of `mcp-server-sqlite` (`list_tables`, `describe_table`, `read_query`) and `mcp-server-git` (`git_log`, `git_show`, `git_diff_unstaged`; 30 per tool) succeeded under GERMLINE with the same output as the unprotected server, 780 calls in total, apart from the clock value reported by `get_current_time`. `mcp-server-git` ran with `/dev/null` read-write in the germline; with the strict read-only binding the server cannot start, because GitPython runs `git version` at import and git opens `/dev/null` read-write. The fetch tool's destination host comes from its URL argument, so the harness declared the host named there (`api.example`) for each call, as A5 permits. On the cloud container, with each copy in its own PID namespace, P50 latency rises from 1.4 to 49.7 ms for `convert_time` (15.6 ms with a pool) and from 1.2 to 47.0 ms for `get_current_time` (11.2 ms with a pool), from 18.4 to 110.3 ms for `fetch` (73.3 ms with a pool), from 1.6–2.0 to 39.0–41.2 ms for the sqlite tools and from 9.6–17.6 to 57.8–74.5 ms for the git tools.

E. Dampening analysis

Rule. GERMLINE keeps one penalty P per release, which starts at zero, so an authenticated update also starts at zero. On every call to the release, including calls refused while it is suppressed, the penalty first decays, $P \leftarrow \lambda P$ with $\lambda = 2^{-1/h}$, and then grows by the weight of the call's event, if any: $w = 250$ for an unverified event and 2000 for a verified witness from a release that declared determinism or for a broken determinism declaration (Table XIV). The release is suppressed once $P \geq S = 2000$ and usable again once $P < R = 750$. The operating point is $h = 50$ calls and $w = 250$.

Stationary mean. Let a release produce an unverified event on each call independently with probability p. The expected penalty then evolves as $\mathbb{E}[P_{n+1}] = \lambda\,\mathbb{E}[P_n] + wp$ and converges to the stationary mean

$$\bar{P} = \frac{wp}{1-\lambda} \approx \frac{wph}{\ln 2},$$

since $1 - \lambda \approx \ln 2/h$ for large h. The mean reaches S at the rate $p^* = S(1-\lambda)/w$, which is 11.0% at the operating point. This is a statement about the mean only: the penalty of a single release fluctuates around $\bar{P}$, so a release whose rate lies below p^* can still cross S during a run of events, and finite-horizon probabilities must be measured, which Table XV does.

Time to suppress and recovery. From $P = 0$, k consecutive events give $P = w(1-\lambda^k)/(1-\lambda)$, which first reaches S at $k = 9$, so a release that diverges on every call is suppressed after 9 calls. Along the expected-penalty trajectory, in which each call adds pw, a release that diverges on 50% of its calls reaches S after 18 calls and one at 20% after 58, while one at 10% never does, because $10\% < p^*$. A verified witness from a release that declared determinism adds 2000 and suppresses the release at once. Without further events, the penalty falls from S to R in $\lceil h \log_2(S/R) \rceil = 71$ calls; because refused calls also advance the decay, a suppressed release becomes usable again after 71 further call attempts, while an idle release keeps its penalty. Because the adversary controls updates and may steer the agent, it can reset the penalty with an update or speed recovery with refused calls; dampening therefore carries no guarantee, while verified witnesses remain valid evidence against the release hash they name across updates.

Finite-horizon simulation. Table XV estimates the probability that a release is suppressed at least once within 1,000, 10,000 or 100,000 calls, with 2,000 simulated releases per cell (500 for 100,000 calls). Under a random schedule, each call diverges independently with probability p; under a bursty schedule with the same long-run rate, divergences arrive in bursts of 10 calls, during which each call diverges with probability 0.5. At 1% random divergence no release is suppressed even within 100,000 calls, and at 3% the probability is 0.15% within 1,000 calls, 2.4% within 10,000 and 23.2% within 100,000. Bursty releases are suppressed far more often at the same mean rate, because the rate inside a burst, 50%, exceeds p^*; this is a property of the policy, which reacts to the local divergence rate rather than to the long-run average.

Parameter sweep. Fig. 5 plots p^* for half-lives of 25–400 calls and weights of 100–1000. A line below the 3% reference means that the stationary mean penalty of a release diverging on 3% of its calls exceeds S, which happens exactly in the cells with $h{\cdot}w \geq 50{,}000$; at the operating point, $h{\cdot}w = 12{,}500$. A separate simulation with 800 releases per cell shows the trade-off around the operating point ($w = 250$, $S = 2000$; probability of false suppression within 10,000 calls at 1% and 3% random divergence, and calls to suppress a release

TABLE XV
PROBABILITY (%) THAT DAMPENING SUPPRESSES A RELEASE AT LEAST ONCE WITHIN N CALLS, AT THE OPERATING POINT ($h = 50$, $w = 250$, $S = 2000$, $R = 750$; $p^* = 11.0\%$). RANDOM: EACH CALL DIVERGES INDEPENDENTLY WITH PROBABILITY p. BURSTY: SAME LONG-RUN RATE, BURSTS OF 10 CALLS AT 50%. "–": NOT SIMULATED.

	Random			Bursty		
p	10^3	10^4	10^5	10^3	10^4	10^5
1%	0	0	0	11.55	74.35	100
2%	0.05	0.05	–	34.95	99.6	–
3%	0.15	2.4	23.2	61.25	100	100
4%	2.25	28.35	–	82.2	100	–
5%	15.8	86.4	100	91.85	100	100

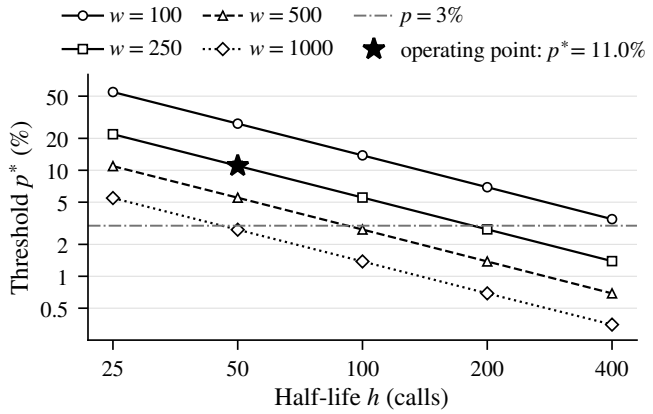

Fig. 5. Dampening threshold p^*, the divergence rate at which the stationary mean penalty reaches S (log scale), against half-life h for weights $w \in \{100, 250, 500, 1000\}$. The star marks the operating point ($h = 50$, $w = 250$, $p^* = 11.0\%$). A line below the dash-dotted 3% reference means the mean penalty of a release diverging on 3% of its calls exceeds S; finite-horizon probabilities are in Table XV.

that always diverges): $h = 25$ gives 0% and 0% and 9 calls ($p^* = 22\%$); $h = 50$ gives 0% and 2.9% and 9 calls ($p^* = 11\%$); $h = 100$ gives 0% and 98% and 9 calls ($p^* = 5.5\%$). The 2.9% at $h = 50$ and the 2.4% of Table XV estimate the same probability from 800 and 2,000 releases. Halving the weight instead ($w = 125$, $h = 100$) also gives 0% and 0% but needs 17 calls. The operating point $h = 50$ thus suppresses an always-diverging release as fast as any setting with $w = 250$ while keeping false suppression at 3% random divergence low within 10,000 calls; the same simulation at $h = 100$ is kept in `e12_montecarlo_h100.json`.

APPENDIX C
ETHICS

All experiments ran in an isolated testbed on machines we control, with test data and destination hosts set up for this study. No third-party systems, services or users were involved. MCPGuard-Dynamic was built from its public repository and run only on our own machines. The disclosure we report is a threat-model boundary of destination-based confinement, which binds authority to destinations rather than to individual items (Section VII-B); it does not exploit an implementation flaw in MCPGuard. Because the finding concerns a design boundary rather than a vulnerability, no vendor notification was needed. The signed attack releases and the generated-variant corpus can be used to build tools that disclose data, so we share them only through restricted access to researchers on request (Appendix D).

APPENDIX D
ARTIFACT AVAILABILITY

All artifacts needed to evaluate the contributions of this paper will be released with the conference version of this paper. The repository contains the prototype, the testbed, the experiment harnesses and the frozen result files, so that every reported number, table and figure can be traced to a file and regenerated.

Prototype. The artifact contains the source of GERMLINE. Its enforcement path consists of the broker and germline fork server, the per-copy confinement (namespaces, Landlock rule-set, PID namespace per copy), Plan with declared-destination splitting and the clearance split, per-horizon state slots with their labels, and the per-copy deadline; the broker does not follow redirects. Its evidence path consists of the twin shim, the per-destination sequence comparison with positional reply replay, witness recording with the probe-replay `verify()`, and the dampening module. The baseline runtimes Sig+Pin, Sig+IFC, Confined+IFC, Fresh+IFC and GERMLINE-NoSplit are implemented in the same code base and selected by configuration, as are the switches that turn each mechanism off for the implementation correspondence tests of Tables VI and XII. The property tests for O1–O5 and the regression tests for slot labels, sequence comparison, the per-copy deadline and redirects are included with their expected outputs.

Testbed. The testbed consists of the 59 signed releases (the five MCP servers with their five flow-compliant releases and 52 signed updates carrying hidden code, and the two benchmark releases of Section VII-F), the test publisher key and TUF-style metadata, the generator for the test world with its labels, clearances and per-trial canary items, the HTTP sinks, and the disclosure oracle. The attack variants are those of Section III-B.

Harnesses and results. The artifact contains the scripts that run E1–E13 and the frozen result files of every experiment in Table IX: E1, E2, E3 (three passes), E4, E5, E6 (three repetitions), E7, E8-A, E8-C, E9 (existence bit and deniability), E10, E11, E12, E13 (three trials), the twin test, the obligation tests on both platforms and the regression tests. It also contains the compatibility harness for unmodified MCP servers and the two workflow tests of Section VII-D, and the Monte-Carlo and parameter-sweep scripts behind Appendix B-E. Table IX lists, for every experiment, its result file, its platform and the code version it measured. The plotting scripts and figure sources regenerate every figure from these files.

README. A top-level README gives a minimal runnable example, one scripted session of one tool server under a baseline runtime and under germline execution, with its expected output, so that a reviewer can check the installation before running the full harnesses. It states the exact versions of the kernel, Python, the Python packages and the model-serving stack used for each platform, the machine requirements of

each harness and its run time, and a map from every table and figure of the paper to the result file and script it is computed from.

MCPGuard comparison. Instead of redistributing MCPGuard-Dynamic, the artifact names its public repository and the commit we built (commit `825fdc0a`, 6 Oct 2026), together with our build steps: `vmlinux.h` regenerated for the server kernel, one line that registers our document server in the proxy's server table, and one build flag that includes `vmlinux.h` first; MCPGuard's enforcement code is unchanged. It contains our least-privilege policies in MCPGuard's format for the six-call session, which we used with MCPGuard's proxy and its AgentBound reproduction. It also contains the E8-A and E8-C runner scripts, the tags of the four eBPF programs as loaded in every E8 run (`file_guard_open`, `net_guard_connect`, `proc_guard_exec` and `fork_guard_sched_fork`), and the positive-control transcript. With these, a reviewer can rerun the session and observe both the blocked raw-socket transfer and the disclosure through the authorised OCR destination host.

CaMeL check. The artifact includes the script and its log for the labelling check of Section VII-C, which runs CaMeL's reference interpreter and Workspace policy at commit `f083b6b` without a language model.

Generated-variant corpus and external components. The E13 corpus of generated variants is our own: we generated it with a locally served model (Qwen3.5-27B) through an orchestration pipeline built with an LLM coding agent (Codex), and we validated, signed and benchmarked every variant ourselves (Section VII-C). The artifact contains the generation pipeline with its settings and per-attempt seeds, the E13 benchmark runner, the validation procedure and the per-case results, so the funnel from 189 generation attempts to 91 validated variants and the prevention rates can be checked against the result file. Model weights (Qwen3-32B-AWQ [25] and the generator) and the serving stack (vLLM 0.11 [51]) are obtained from their public sources and are not redistributed.

Requirements. The prototype and E1–E5, E7 and E9–E13 run on stock Linux without kernel changes; they need PID, network and IPC namespaces, Landlock and Python. The cloud container (2 vCPU) ran Linux 6.18 with Landlock ABI 7 and Python 3.13; the server ran Linux 6.8 with ABI 4 and Python 3.12. The MCPGuard comparison (E8) additionally needs the BPF LSM enabled through the kernel boot parameter. E6 needs GPUs to serve its model, and so does generating the E13 corpus anew with the generator model; we served the E6 model on NVIDIA RTX 5000 Ada GPUs with 32 GB each in a server virtual machine with 24 cores and 96 GB RAM. Running the E13 benchmark on the released corpus needs no GPU. On the server, E6 takes about 40 minutes for three repetitions, one E3 pass about 1 to 3 minutes, E13 about 1 minute per trial, and E5 and E8-C under a minute each; the README lists the run time of every harness.

Availability and licences. The package will be archived on Zenodo with a DOI. Code is released under the MIT licence and data and results under CC BY 4.0, with a `CITATION.cff` file giving the preferred citation. The signed attack releases and the generated-variant corpus are released under the same licences as a restricted-access Zenodo record, available to researchers on request (Appendix C); all other components are public.